CASE STUDY

The Year 2011 in Intrusions: A Dated Record

A TeamStarWolf case study. Published 13 November 2026; every source checked as of that date.

Executive summary

The year's trust failures happened in public. On 15 March an attacker used one compromised user account at one Comodo Registration Authority to issue nine certificates for seven domains, including mail.google.com, login.live.com, login.yahoo.com, login.skype.com and addons.mozilla.org; all were revoked, and only one login.yahoo.com certificate was seen live (Confirmed [5]). Mozilla blocked the certificates on 22 March, and Microsoft's Advisory 2524375 and a US-CERT alert followed on 23 March (Confirmed [8][6][7]). On 19 July the Dutch CA DigiNotar detected an intrusion into its certificate infrastructure that resulted in fraudulent certificates, including for Google.com (Confirmed [26]). On 29 August Google reported attempted SSL man-in-the-middle attacks on users primarily in Iran with a fraudulent DigiNotar certificate, which Chrome detected; Microsoft, Mozilla and US-CERT acted within a day, Google rejected every DigiNotar CA on 3 September, and DigiNotar was declared bankrupt on 20 September (Confirmed [28][29][31][30][33]). Comodo judged its attack likely state-driven from IP indicators it calls circumstantial, and DigiNotar called its hack politically inspired; both are the companies' assessments, not government findings (Reported [5][32]).

A security vendor's own product secrets were taken. EMC filed RSA's open letter on 17 March: an attack RSA classes as an Advanced Persistent Threat extracted information related to SecurID two-factor products, which RSA said could reduce a deployment's effectiveness as part of a broader attack (Confirmed [10]). EMC's 10-Q of 5 August records a USD 66.3 million second-quarter charge for expanded SecurID remediation; EMC expanded the programs in June after press coverage of an unsuccessful attack on an unnamed defense-sector customer (Confirmed [11]). Lockheed Martin said it detected a "significant and tenacious attack" on 21 May and that no customer, program or employee personal data was compromised; it named no attacker, and the link between its incident and RSA's was not checked (Confirmed [60]). Adobe's APSA11-01 of 14 March reported a Flash zero-day, CVE-2011-0609, exploited in targeted attacks through a file embedded in an Excel e-mail attachment; whether that was RSA's entry point was not checked against a primary (Confirmed [12]; the RSA link not checked).

Consumer platforms lost data at scale. Sony said intruders reached PlayStation Network and Qriocity account data between 17 and 19 April, turned the services off, and reported to the SEC that personal information from about 24.6 million Sony Online Entertainment accounts may also have been stolen (Confirmed [17][19][18]). Epsilon, Valve's Steam and NASDAQ OMX disclosed intrusions of their own (Confirmed [14][48][3]). Hacktivist cases ran through the year: federal charges unsealed in March 2012 allege that LulzSec, formed in May 2011, hacked PBS, Sony Pictures and Bethesda Softworks, and the FBI arrested 16 people on 19 July over the 2010 PayPal attacks and related intrusions (Reported as charged [4]; Confirmed [24][21]).

The year's Stuxnet relative was Duqu. CrySyS Lab's report of 14 October found massive Stuxnet code reuse and a driver signed with a Taiwanese hardware maker's certificate; Symantec dated the first recorded attack to early April and found one delivery through a Word document carrying a then-undisclosed Windows kernel flaw, which Microsoft fixed as CVE-2011-3402 in MS11-087 on 13 December (Confirmed [39][40][42][44]). ICS-CERT said Duqu targeted neither industrial control systems nor their vendors (Confirmed [41]). Night Dragon, the espionage campaign McAfee published on 10 February against oil, energy and petrochemical companies, ended in February in ATT&CK's record (Confirmed [2][1]).

Courts and companies took botnets down. Microsoft's civil actions removed Rustock in March and Kelihos in September, the Justice Department used a court order to send stop commands to Coreflood-infected computers in April, and Operation Ghost Click charged six Estonian nationals and one Russian national in November over DNSChanger, which allegedly infected more than four million computers (Confirmed [9][34][16][46]). Policy and standards moved: the White House International Strategy for Cyberspace (May), the DoD Strategy for Operating in Cyberspace (July), the SEC's cybersecurity disclosure guidance (October), the UK Cyber Security Strategy (November), FedRAMP (December), NIST's guidance on continuous monitoring and cloud computing, and RFCs that prohibited SSL 2.0 and set the rules for checking a TLS server's identity (Confirmed [20][65][38][92][94][79][80][83][84]).

This study records the year by date. It is built only from sources opened on 12 and 13 November 2026 and from checks of the library's data run on those days, and is checked as of 13 November 2026.

Key facts at a glance

Field	Value
Period	1 January to 31 December 2011, plus the records that open, close or explain a 2011 event: Night Dragon from November 2009, the Internet Feds and PayPal events from December 2010, the March 2012 charges, Flame's 2012 disclosure, Mandiant's APT1 report of February 2013, the 2014 PLA and 2016 Iran indictments, and KEV additions from 2022 to 2025
The certificate authority failures	Comodo RA account abused (15 Mar); Mozilla blocks (22 Mar); Advisory 2524375 (23 Mar); DigiNotar intrusion detected (19 Jul); Google, Microsoft and Mozilla act (29 Aug); Google rejects DigiNotar (3 Sep); DigiNotar bankrupt (20 Sep); DigiCert Sdn. Bhd. weak keys (10 Nov) (Confirmed [5][8][6][26][28][29][31][33][49])
RSA SecurID	8-K with RSA's open letter (17 Mar); Lockheed Martin detects an attack (21 May); remediation expanded (Jun); USD 66.3 million charge (10-Q, 5 Aug) (Confirmed [10][60][11])
Duqu	First recorded attack (early Apr); CrySyS report (14 Oct); Symantec v1.0 (18 Oct); ICS-CERT alert (Oct); Advisory 2639658 (3 Nov); MS11-087 (13 Dec) (Confirmed [40][39][41][42][44])
Consumer and corporate breaches	NASDAQ OMX (Feb); Epsilon (8-K, 6 Apr); PlayStation Network and Qriocity (17 to 19 Apr); SOE, about 24.6 million accounts (6-K, 3 May); Sony Pictures (27 May to 2 Jun); Steam (6 Nov) (Confirmed [3][14][17][18][21][48])
Hacktivism and arrests	LulzSec formed (May, as charged); 16 US arrests (19 Jul); Monsegur's plea (15 Aug); Kretsinger arrested (22 Sep); Stratfor (Dec, as charged) (Reported [4]; Confirmed [24][4][21])
Botnet takedowns	Rustock (16 Mar); Coreflood (13 Apr); Kelihos (26 Sep); Ghost Click and DNSChanger (8 and 9 Nov) (Confirmed [9][16][34][46])
Exploited in 2011 per NVD or the vendor	CVE-2011-0609, -0611, -2462 (Adobe); CVE-2011-3402 (Windows, Duqu); CVE-2011-3192 (Apache); CVE-2011-4862 (telnetd) (Confirmed [12][13][15][50][43][27][75])
KEV tail	Nine CVE-2011 entries in catalog 2026.11.10, added from 3 March 2022 to 6 October 2025 (Confirmed [54])
Microsoft's year	MS11-001 (11 Jan) to MS11-100 (29 Dec, out of band): 100 bulletins by numbering (Confirmed [68][53]; count Inferred)
CVE volume	4,172 CVE records published in 2011 by NVD publication date (Confirmed [95])
Policy and standards	SP 800-39 (Mar); RFC 6176 and RFC 6125 (Mar); International Strategy for Cyberspace (May); CWE/SANS Top 25 and CWE 2.0 (27 Jun); DoD Strategy (Jul); SP 800-137 and SP 800-145 (Sep); SEC Topic No. 2 (13 Oct); UK strategy (25 Nov); FedRAMP (8 Dec) (Confirmed [78][83][84][20][88][89][65][79][80][38][92][94])
This study's MITRE binding	66 ATT&CK Enterprise techniques in 82 technique-tactic entries: 54 listed by ATT&CK for Night Dragon (C0002), Duqu (S0038) or APT1 (G0006), ten described by a primary and assigned here, one from a Reported source and one inferred; three ATT&CK for ICS techniques listed for Duqu; CWE ids from NVD; CAPEC and D3FEND pairings from the library's data; one Enterprise Navigator layer (Part 13)

Key findings

- **2011 tested the web's certificate trust model in public.** One CA's registration authority was abused in March, a second CA was breached in July and went bankrupt in September, and a third issued weak-key certificates that Microsoft untrusted in November (Confirmed [5][26][33][49]; Inferred for the reading).
- **Detection to disclosure took six weeks at DigiNotar.** The intrusion was detected on 19 July; Google's report of attacks in Iran came on 29 August, and the parent company's statement on 30 August said at least one fraudulent certificate had not been revoked (Confirmed [26][28]).
- **Browsers and operating systems did the revoking.** Mozilla and Microsoft acted within a week of Comodo's report to Microsoft, and Google, Microsoft, Mozilla and US-CERT within a day of the DigiNotar disclosure; Microsoft warned that revocation checks can fail open, and vendors removed trust outright (Confirmed [8][6][28][29][31][30]; Inferred for the reading).
- **Chrome caught DigiNotar, most likely through pinning.** A Chrome engineer wrote on 4 May that from Chrome 13 most Google properties carry public key pins, and Google said on 29 August that Chrome detected the fraudulent certificate without naming the mechanism (Confirmed [90][28]; Inferred for the link).
- **A vendor's secrets became a customer's risk.** RSA said the stolen SecurID information could weaken a two-factor deployment in a broader attack, and EMC recorded a USD 66.3 million second-quarter charge to remediate customers (Confirmed [10][11]).
- **Documents carried at least two of the zero-days.** CVE-2011-0609 arrived in an Excel e-mail attachment and Duqu's kernel flaw in a Word document; NVD records CVE-2011-0611 as demonstrated with an Office document and gives no vector for the Reader flaw CVE-2011-2462 (Confirmed [12][40][15][50]).
- **Duqu reused Stuxnet's code but not its target.** CrySyS found the code reuse, and ICS-CERT found no ICS targeting (Confirmed [39][41]).
- **Takedown went to court.** Two Microsoft civil cases, a government order to stop running malware, and a criminal case that replaced rogue DNS servers with clean ones all landed in one year (Confirmed [9][34][16][47]; Inferred for the reading).
- **Disclosure became a securities question.** The SEC's guidance of 13 October asked registrants to disclose material cyber risks and incidents, after a year of 8-K and 6-K filings about breaches (Confirmed [38][10][14][18][26]).
- **No 2011 event had an ATT&CK mapping at the time, and KEV came a decade later.** Every technique id in Part 13 is a later mapping, and the nine CVE-2011 KEV entries were added from 2022 to 2025 (Confirmed [54]; Inferred).

Top recommendations

1. **Plan for a CA you trust to fail.** Comodo, DigiNotar and DigiCert Sdn. Bhd. each led to a Microsoft trust-store advisory (2524375, 2607712 and 2641690); keep an inventory of the roots and intermediates your systems trust and a way to remove one quickly (Confirmed [6][29][49]; Inferred for the control).
2. **Do not rely on revocation alone.** Microsoft warned that revocation checks can fail open, and it and other vendors shipped untrust updates instead (Confirmed [6][29]).
3. **Pin or constrain the certificates for your most sensitive services.** Chrome detected the DigiNotar certificate used against Google users, and Chrome 13 carried pins for Google properties (Confirmed [90][28]; Inferred that the pins did the detecting).

4. **Treat a supplier's breach as your incident.** RSA told customers to strengthen their SecurID deployments, and EMC replaced tokens at scale (Confirmed [10][11]).
5. **Filter documents with embedded active content.** The March Flash flaw arrived inside an Excel attachment, and NVD records the April flaw as demonstrated with an Office document (Confirmed [12][15]).
6. **Patch kernel font parsing and keep the workaround ready.** Advisory 2639658 offered a workaround six weeks before MS11-087 (Confirmed [42][44]).
7. **Check e-mail forwarding and delegation settings after a phishing wave.** The Gmail campaign changed both on stolen accounts (Confirmed [22]).
8. **Use strong passwords on Remote Desktop.** Morto spread by guessing weak administrator passwords (Confirmed [67]).
9. **Bound request size and cost on web servers.** The Apache Range-header and hash-collision flaws let crafted requests exhaust server resources (Confirmed [27][52]).
10. **Do not read KEV dates as event dates.** CVE-2011-3402 was exploited in November 2011 and added to KEV in October 2025 (Confirmed [43][54]).

Scope and method

This study covers intrusions, certificate authority failures, vulnerabilities, malware, botnets, data breaches, hacktivism and prosecutions, state and espionage operations, industrial incidents, regulation, standards and policy dated to 2011, plus the later records that open, close or explain a 2011 event. It follows the method of the case studies collection: primary sources first, every claim graded, and numbers given as the source states them. Every external source was opened on 12 or 13 November 2026, as the Sources table shows, and the library data checks were run on the same days.

Grade	Meaning in this study
Confirmed	The primary record was opened and states the fact: a vendor advisory or bulletin, a CA's incident report, a company's own statement or SEC filing, a CERT/CC, US-CERT, ICS-CERT or CISA record, a CVE or NVD record, the KEV catalog, an FBI or US Attorney release, a government strategy, order or memorandum, a NIST, IETF or MITRE record, a researchers' or vendor's report stated as its own finding, a live ATT&CK page, or a library study, only for the fact that it is the home for an event
Reported	Only a secondary source supports the fact, or a source relays someone else's claim or makes an attribution that is its own assessment: the alleged hacks in the March 2012 charges, Comodo's and DigiNotar's attributions, the Mandiant report quoting a congressman, and the ICS-CERT Monitor quoting the press. The source is named in the text
Demonstrated	A check this study ran itself and saw the result (id, name, tactic and page checks in the library's data files and `mitre/` tree), or a researchers' analysis of a sample they hold (CrySyS on Duqu)
Inferred	The study's own reading, labelled where it appears. Every ATT&CK, CAPEC and D3FEND id bound to a 2011 event is Inferred as to the binding unless ATT&CK lists it for the object, and so is every CWE that NVD does not list

Charges, complaints and indictments are allegations; where this study cites one, the record confirms that the charge was made, not that it was proven. Company statements are the company's own account, and vendor and researcher attributions are those authors' assessments, not government findings.

Limits a reader should know:

- **CVE existed; ATT&CK and KEV did not.** Every 2011 product flaw here carries a CVE id. No ATT&CK mapping existed in 2011, so every technique id in Part 13 is assigned in hindsight from later ATT&CK records or by this study (Inferred). KEV's 2011 entries were added from March 2022 to October 2025 (Confirmed [54]).
- **Some events have no id of any kind.** The Comodo and DigiNotar attackers, the RSA intruders, the Gmail campaign, Rustock, Kelihos, Coreflood, DNSChanger, Morto and the hacktivist groups have no ATT&CK object in the library's data (Demonstrated [100]).
- **Two vendor papers came from copies.** McAfee's Night Dragon paper was read from a third-party mirror after McAfee's own copy returned an error, and the DoD Strategy for Operating in Cyberspace was read from a NIST-hosted copy after defense.gov refused the request (Confirmed [2][65]).
- **What was not checked.** No primary was opened, or the page would not open, for: RSA's own technical account of its intrusion (carried by the FireEye Mandiant intrusion study, not reopened here); the link between the RSA and Lockheed Martin incidents; the Fox-IT reports on DigiNotar ("Operation Black Tulip") and their certificate counts; McAfee's Operation Shady RAT paper; ONCIX's November 2011 report on economic espionage; the Lynn speech's "24,000 files" figure; Symantec's Nitro paper; the AlienVault Sykipot post and its date; Novetta's Operation Blockbuster report and the date of Ten Days of Rain; the justice.gov releases for the 2014 PLA and 2016 Iran indictments, and which 2014 counts fall in 2011; Mitsubishi Heavy Industries' September statement; Sony's letters to Congress; Citigroup's June card-account disclosure; Adobe's APSA11-04; the Illinois water pump claim and the Texas water event at a primary; the FFIEC's June 2011 authentication supplement; the HHS HIPAA penalties of 2011; the FTC's April 2011 releases; ISO/IEC 27005:2011 and 27035:2011; EMET; the Facebook and Microsoft bounty programs; CAPEC releases in 2011; the South Korean Nonghyup outage, the SK Communications breach, the Booz Allen and CIA.gov events, Mt. Gox, the Japanese parliament intrusion and Nexon; and the Zeus source leak, SpyEye and ZeroAccess. They are left out or marked "not checked" where they touch a verified fact. Their absence here is not evidence that nothing happened.

Part 1: the year as a dated timeline

One row per event or report. The date is the event date where the source gives one, otherwise the publication date. Rows marked "frame" or "boundary" open or close a 2011 event.

Date	Event	Thread	Sector	Grade	Sources
2009-11 to 2011-02 (frame)	Night Dragon campaign against oil, energy and petrochemical companies (ATT&CK C0002). Home: China-attributed threat actors	Espionage (China-based actors, per researchers)	Energy	Confirmed; attribution Reported	[1][2]

Date	Event	Thread	Sector	Grade	Sources
2010-12 to 2011-05 (frame)	Internet Feds members hack HBGary, HBGary Federal and Fox, as charged. Home: Four Books on Cybercrime	Hacktivism	Security, media	Reported (as charged)	[4]
2010-12-06 to 2010-12-10 (frame)	DDoS on PayPal ("Operation Avenge Assange"), as charged in 2011. Year of the attack: The Year 2010 in Intrusions	Hacktivism	Payments	Confirmed (as charged)	[24]
2011-01	APT1 compromises at least 17 new victims in 10 industries, per Mandiant's 2013 report	State	Multiple	Confirmed (vendor's finding)	[56]
2011-01-11	MS11-001, the year's first Microsoft bulletin	Vulnerability	Cross-sector	Confirmed	[68]
2011-02	Symantec's Stuxnet dossier v1.4. Home: Stuxnet	State	Industrial	Confirmed	[55]
2011-02-10	McAfee publishes "Global Energy Cyberattacks: Night Dragon"	State	Energy	Confirmed	[2]
2011-02 (10-K 24 Feb)	NASDAQ OMX says it detected suspicious files on its US servers and removed them	Intrusion	Finance	Confirmed (company's account)	[3]
2011-03	NIST SP 800-39; RFC 6176 prohibits SSL 2.0; RFC 6125 on TLS server identity	Standards	Government; internet	Confirmed	[78][83][84]
2011-03-14	Adobe APSA11-01: Flash CVE-2011-0609 exploited in targeted attacks through an Excel e-mail attachment	Vulnerability	Cross-sector	Confirmed	[12]
2011-03-15	Comodo RA user account abused to issue nine certificates; CVE-2011-0609 published	Trust; Vulnerability	Internet	Confirmed	[5][13]
2011-03-16	Comodo informs Microsoft; Microsoft and the US Marshals take Rustock offline (Operation b107)	Trust; Botnet takedown	Internet; technology	Confirmed	[6][9]
2011-03-17	EMC 8-K carries RSA's open letter on the SecurID-related theft	Intrusion	Security vendor	Confirmed	[10]
2011-03-22	Mozilla blocks the fraudulent Comodo certificates	Trust	Browsers	Confirmed	[8]
2011-03-23	Microsoft Advisory 2524375; US-CERT "Fraudulent SSL Certificates"; Comodo's incident report	Trust	Internet	Confirmed	[6][7][5]

Date	Event	Thread	Sector	Grade	Sources
2011-03-26	Comodo stops a second attempt	Trust	Internet	Confirmed (company's account)	[5]
2011-04 (early)	First recorded Duqu attack, per Symantec	Espionage (no state named)	Multiple	Confirmed	[40]
2011-04	RFC 6265 on HTTP cookies	Standards	Web	Confirmed	[85]
2011-04-06	Alliance Data 8-K: Epsilon detected unauthorized entry into its e-mail system the week before	Breach	Marketing	Confirmed (company's account)	[14]
2011-04-13	CVE-2011-0611 published; DOJ and FBI move against Coreflood	Vulnerability; Botnet takedown	Cross-sector; finance	Confirmed	[15][16]
2011-04-16 to 2011-04-17	Sony Online Entertainment account data may have been stolen	Breach	Gaming	Confirmed	[18]
2011-04-17 to 2011-04-19	Intrusion into PlayStation Network and Qriocity	Breach	Gaming	Confirmed	[17]
2011-04-26	Sony's PlayStation Blog discloses the PSN intrusion	Breach	Gaming	Confirmed	[17]
2011-05	International Strategy for Cyberspace; LulzSec formed, as charged	Policy; Hacktivism	Government; multiple	Confirmed; Reported (as charged)	[20][4]
2011-05-02 to 2011-05-03	Sony 6-K filings on the San Diego data center attack and SOE	Breach	Gaming	Confirmed	[19][18]
2011-05-04	Chrome engineer describes public key pinning for Google properties from Chrome 13	Trust	Browsers	Confirmed	[90]
2011-05-12	White House Cybersecurity Legislative Proposal	Policy	Government	Confirmed	[77]
2011-05-21	Lockheed Martin detects a "significant and tenacious attack" (statement 28 May)	Intrusion	Defense	Confirmed (company's account)	[60]
2011-05-27 to 2011-06-02	Sony Pictures systems compromised, per the FBI	Hacktivism	Media	Confirmed (as charged)	[21]
2011-06	EMC expands SecurID remediation after press coverage of an attack on a defense customer	Intrusion	Security vendor; defense	Confirmed	[11]
2011-06-01	Google discloses a phishing campaign against personal Gmail accounts, apparently from Jinan	Espionage (unattributed)	Government, NGO, media	Confirmed	[22]

Date	Event	Thread	Sector	Grade	Sources
2011-06-02	US-CERT "Gmail Phishing Attack" alert	Espionage (unattributed)	Government	Confirmed	[23]
2011-06-09	CVE-2011-1823 (Android "Gingerbreak") published	Vulnerability	Mobile	Confirmed	[69]
2011-06-14	MS11-040 fixes the Forefront TMG client flaw CVE-2011-1889	Vulnerability	Cross-sector	Confirmed	[70]
2011-06-21	Tampa Bay InfraGard site intrusion, as charged	Hacktivism	Government partnership	Confirmed (as charged)	[24]
2011-06-27	2011 CWE/SANS Top 25 and CWE 2.0	Standards	Software	Confirmed	[88][89]
2011-07	DoD Strategy for Operating in Cyberspace	Policy	Defense	Confirmed	[65]
2011-07-19	DigiNotar detects its intrusion; FBI arrests 16; US-CERT TA11-200A	Trust; Hacktivism; Advisory	Internet; payments; cross-sector	Confirmed	[26][24][25]
2011-08	RFC 6101 publishes SSL 3.0 as Historic	Standards	Internet	Confirmed	[86]
2011-08-05	EMC 10-Q records a USD 66.3 million SecurID remediation charge	Intrusion	Security vendor	Confirmed	[11]
2011-08-09	MS11-058 fixes a Windows DNS Server flaw	Vulnerability	Cross-sector	Confirmed	[74]
2011-08-15	Hector Xavier Monsegur pleads guilty (unsealed 6 Mar 2012)	Hacktivism	Multiple	Confirmed	[4]
2011-08-24	Apache advisory on the Range-header denial of service CVE-2011-3192	Vulnerability	Web	Confirmed	[27]
2011-08-29	Google reports attempted man-in-the-middle attacks on users primarily in Iran with a fraudulent DigiNotar certificate; Microsoft and Mozilla act the same day	Trust	Internet	Confirmed	[28][29][31]
2011-08-30	US-CERT DigiNotar alert; VASCO 8-K on the intrusion	Trust	Internet	Confirmed	[30][26]
2011-09	NIST SP 800-137 and SP 800-145; RFC 6376 (DKIM)	Standards	Government; e-mail	Confirmed	[79][80][87]
2011-09-02	Sealed indictment returned against Cody Kretsinger	Hacktivism	Media	Confirmed	[21]
2011-09-03	Google rejects all DigiNotar CAs	Trust	Browsers	Confirmed	[28]

Date	Event	Thread	Sector	Grade	Sources
2011-09-06	CVE-2011-3389 (BEAST) published; KB2607712 untrusts DigiNotar roots	Vulnerability; Trust	Internet	Confirmed	[37][29]
2011-09-07	DigiNotar statement on Iranian targets (VASCO 8-K Ex. 99.3)	Trust	Internet	Confirmed (filing); Reported (purpose)	[32]
2011-09-13	KB2616676 untrusts 11 DigiNotar certificates; CWE 2.1 and Top 25 v1.0.3	Trust; Standards	Internet; software	Confirmed	[29][89][88]
2011-09-19 to 2011-09-20	DigiNotar files for bankruptcy and is declared bankrupt	Trust	Internet	Confirmed	[33]
2011-09 to 2011-10	First Gauss infections, mostly in Lebanon, as the home study carries Kaspersky. Home: Stuxnet	State	Not stated	Reported (carried)	[103]
2011-09-22	Kretsinger arrested; Microsoft seeks a restraining order against Kelihos	Hacktivism; Botnet takedown	Media; technology	Confirmed	[21][34]
2011-09-26	Kelihos taken down; Microsoft Advisory 2588513 on BEAST	Botnet takedown; Vulnerability	Technology; internet	Confirmed	[34][36]
2011-09-27	US-CERT "SSL/TLS Protocol Vulnerability"	Vulnerability	Internet	Confirmed	[35]
2011-10-04	HPSCI open hearing on cyber threats, as quoted by Mandiant	Policy	Government	Reported	[56]
2011-10-07	Executive Order 13587 on classified network security	Policy	Government	Confirmed	[91]
2011-10-11	MS11-080 fixes afd.sys CVE-2011-2005	Vulnerability	Cross-sector	Confirmed	[71]
2011-10-13	SEC CF Disclosure Guidance Topic No. 2. Home: E-Commerce Threats	Regulation	Public companies	Confirmed	[38]
2011-10-14	CrySyS report "Duqu: A Stuxnet-like malware found in the wild"	Espionage (no state named)	Multiple	Confirmed; Demonstrated	[39]
2011-10-18	Symantec W32.Duqu v1.0; new Duqu modules downloaded; ICS-CERT Duqu alert	Espionage (no state named)	Multiple; industrial	Confirmed	[40][41]
2011-10-19	CVE-2011-3544 (Java SE) published	Vulnerability	Cross-sector	Confirmed	[72]
2011-11-03	Microsoft Advisory 2639658 on the TrueType flaw used by Duqu	Vulnerability	Cross-sector	Confirmed	[42]
2011-11-04	CVE-2011-3402 published	Vulnerability	Cross-sector	Confirmed	[43]

Date	Event	Thread	Sector	Grade	Sources
2011-11-06	Steam forums defaced; a Steam database accessed	Breach	Gaming	Confirmed	[48]
2011-11-08	Six Estonians arrested in Operation Ghost Click; MS11-083 fixes a TCP/IP flaw	Crime; Vulnerability	Advertising, consumers; cross-sector	Confirmed	[46][73]
2011-11-09	SDNY charges seven over DNSChanger	Crime	Advertising, consumers	Confirmed (as charged)	[46][47]
2011-11-10	Valve notifies users; Microsoft Advisory 2641690 on DigiCert Sdn. Bhd.	Breach; Trust	Gaming; internet	Confirmed	[48][49]
2011-11-23	Symantec W32.Duqu v1.4	Espionage (no state named)	Multiple	Confirmed	[40]
2011-11-25	UK Cyber Security Strategy	Policy	Government	Confirmed	[92]
2011-11-29	FTC settles with Facebook	Regulation	Social media	Confirmed	[93]
2011-12	NIST SP 800-144 and SP 800-63-1; Stratfor hack, as charged; ICS-CERT chemical and rail incidents; Belgacom intrusion surges, as the home study carries. Home: The Hacker and the State	Standards; Hacktivism; Industrial; State	Government; media; chemical, rail; telecom	Confirmed; Reported	[81][82][4][76][103]
2011-12-07	CVE-2011-2462 (Reader U3D) published	Vulnerability	Cross-sector	Confirmed	[50]
2011-12-08	OMB memorandum establishes FedRAMP	Policy	Government, cloud	Confirmed	[94]
2011-12-12	Threatpost reports a DHS warning after a Texas water system hack, as the ICS-CERT Monitor quotes it	Industrial	Water	Reported	[76]
2011-12-13	MS11-087 fixes CVE-2011-3402	Vulnerability	Cross-sector	Confirmed	[44]
2011-12 (late)	CVE-2011-4862 telnetd overflow exploited in the wild, per NVD	Vulnerability	Servers	Confirmed	[75]
2011-12-28	CERT/CC VU#903934 and US-CERT alert on hash-collision denial of service	Vulnerability class	Web	Confirmed	[52][51]
2011-12-29	MS11-100, out of band, the year's last bulletin	Vulnerability	Web	Confirmed	[53][68]
2011 to 2013 (boundary)	DDoS on the US financial sector, charged in 2016. Homes: Iran-attributed threat actors, 2016 chronicle	State (as charged)	Finance	Confirmed (as charged)	[59]

Date	Event	Thread	Sector	Grade	Sources
2012-03-06 (boundary)	SDNY unseals charges against LulzSec and AntiSec members	Hacktivism	Multiple	Confirmed	[4]
2012 (boundary)	Flame reported; ATT&CK dates it to "at least 2010"	State	Middle East	Confirmed	[64]
2013-02 (boundary)	Mandiant's APT1 report, covering 2011 activity	State	Multiple	Confirmed	[56]
2014-05-01 (boundary)	W.D. Pa. indicts five 3PLA officers	State	Multiple	Confirmed (as charged)	[58]
2022-03-03 to 2025-10-06 (boundary)	KEV adds the nine CVE-2011 entries	Vulnerability	Cross-sector	Confirmed	[54]

Part 2: the certificate authority failures

Comodo

Comodo's incident report says that on 15 March one user account at one Registration Authority was compromised and used to issue nine certificates for seven domains: mail.google.com, www.google.com, login.yahoo.com (three), login.skype.com, addons.mozilla.org, login.live.com and "global trustee" (Confirmed [5]). All were revoked, only one login.yahoo.com certificate was seen live, Comodo says its CA infrastructure and HSM keys were not compromised, and a second attempt on 26 March failed (Confirmed [5]). Comodo says the attack came mainly from Iranian IP addresses, one geolocated to Tehran, calls that evidence circumstantial and concludes the attack was likely state-driven; that is Comodo's assessment, not a government attribution (Confirmed that Comodo says so [5]; the attribution is Reported).

The platform response came in a week. Comodo told Microsoft on 16 March that nine certificates had been signed without sufficient identity validation; Microsoft published Advisory 2524375 on 23 March, moved the certificates into the Untrusted Certificates store, revised the advisory through 6 July, and warned that revocation checks can fail open (Confirmed [6]). Mozilla updated Firefox 4.0, 3.6 and 3.5 on 22 March to recognize and block the certificates, and US-CERT warned on 23 March of the fraudulent certificates and the browser updates that blocked them (Confirmed [8][7]).

DigiNotar

DigiNotar's parent VASCO filed an 8-K on 30 August saying that DigiNotar had detected an intrusion into its CA infrastructure on 19 July that resulted in fraudulent certificates, including for Google.com, and that at least one fraudulent certificate had not been revoked (Confirmed [26]). On 29 August Google reported attempted SSL man-in-the-middle attacks on Google users primarily in Iran with a fraudulent DigiNotar certificate; Chrome detected it, and on 3 September, after the Dutch government's decision, Google rejected all DigiNotar-operated CAs (Confirmed [28]). Mozilla said the same day that it had been told of at least one fraudulent *.google.com certificate in use and shipped Firefox, Thunderbird and SeaMonkey updates revoking trust in the DigiNotar root, with the post updated through 6 September (Confirmed [31]). Microsoft's Advisory 2607712 reported active attacks using at least one fraudulent DigiNotar certificate; Microsoft removed trust in one DigiNotar root through a certificate trust list update on 29 August, untrusted five roots with KB2607712 on 6 September, and untrusted 11 DigiNotar root and cross-signed certificates with KB2616676 on 13 September, rereleased on 19 September (Confirmed [29]). US-CERT's alert of 30 August listed the Mozilla, Google, Apple, Microsoft and Adobe responses (Confirmed [30]).

On 7 September DigiNotar said that the source of certificate validation requests strongly indicated the certificates were used to obtain confidential information of people in Iran, called the hack politically inspired, and said it had engaged Fox-IT; the purpose is DigiNotar's assessment (Confirmed that the filing says so [32]; the purpose is Reported). DigiNotar B.V. filed a voluntary bankruptcy petition on 19 September and the Haarlem District Court declared it bankrupt on 20 September (Confirmed [33]). None of the DigiNotar primaries opened here attributes the intrusion to the Iranian state, so this study names only where the victims were, and the Fox-IT reports were not opened (Inferred [28][32]). The eMudhra CA compromise study carries DigiNotar in its history of CA compromises (Confirmed [103]).

DigiCert Sdn. Bhd.

Microsoft's Advisory 2641690 of 10 November says that DigiCert Sdn. Bhd., a Malaysian subordinate CA under Entrust and GTE CyberTrust, issued 22 certificates with weak 512-bit keys, and US-CERT issued an alert the same day (Confirmed [49]). No intrusion is in the record; the failure was weak issuance (Inferred [49]).

The protocol answers

Three answers to the CA problem date from 2011. A Chrome engineer wrote on 4 May that from Chrome 13 most Google properties carry public key pins, that a chain without a whitelisted key fails, that pins work with HSTS preloading, and that user-installed roots can override them (Confirmed [90]). RFC 6125, published in March, set out how a client checks a TLS server's domain identity (Confirmed [84]). RFC 6176 prohibited SSL 2.0 in March, and RFC 6101 published SSL 3.0 as a Historic RFC in August (Confirmed [83][86]). The BEAST flaw, CVE-2011-3389, a CBC chained-IV weakness in SSL 3.0 and TLS 1.0 that NVD lists as CWE-326, was published on 6 September; Microsoft's Advisory 2588513 followed on 26 September, US-CERT's alert on 27 September, and MS12-006 resolved it on 10 January 2012 (Confirmed [37][36][35]). It is not in KEV (Confirmed [37][54]).

Part 3: RSA SecurID and the defense-sector fallout

EMC filed a Form 8-K under Item 8.01 on 17 March saying that RSA had posted an open letter to customers and sent a SecurCare Online note about an attack, and that EMC did not expect a material financial impact (Confirmed [10]). The open letter, from RSA's Art Coviello, says RSA detected an attack it classes as an Advanced Persistent Threat and that information extracted from its systems relates to SecurID two-factor products; RSA said the information did not enable a direct attack on customers but could reduce the effectiveness of a two-factor implementation as part of a broader attack, and told customers to strengthen their SecurID deployments (Confirmed [10]). The filing does not describe how the attackers got in (Confirmed [10]).

EMC's 10-Q, filed on 5 August, records a USD 66.3 million second-quarter charge for expanded SecurID customer remediation (Confirmed [11]). EMC expanded the programs in June after press coverage of "an unsuccessful cyber attack on one of our defense sector customers", which the filing does not name, and SecurID shipments paused in the first quarter while RSA hardened its internal systems (Confirmed [11]). Lockheed Martin said on 28 May that it detected a significant and tenacious attack on its network on 21 May, that no customer, program or employee personal data was compromised, and that it kept US government agencies informed; it stated no attribution (Confirmed [60]). Whether Lockheed Martin is the customer in EMC's filing, and whether the RSA data was used against it, were not checked against a primary (not checked).

Adobe's APSA11-01, released on 14 March, reports CVE-2011-0609 in Flash Player and in Authplay.dll for Reader and Acrobat as exploited in the wild in targeted attacks through a .swf file embedded in an Excel file sent as an e-mail attachment (Confirmed [12]). NVD published the CVE on 15 March with NVD-CWE-noinfo, and CISA added it to KEV on 8 June 2022 (Confirmed [13][54]). Neither Adobe nor NVD connects the flaw to RSA, and this study did not check that connection (Confirmed [12][13]; the link not checked). The FireEye Mandiant intrusion study carries RSA's 2011 incident in its table of security-vendor breaches, where RSA's own account of 1 April 2011 describes two phishing e-mails carrying an Excel file with the CVE-2011-0609 Flash exploit and a Poison Ivy variant; that source was not reopened here (Confirmed that the home study carries it [103]).

Part 4: the vulnerability record

Exploited at or before the fix

The year's flaws for which the record shows exploitation in 2011, plus the KEV entries without a 2011 exploitation date, in date order:

CVE	Product and flaw	First notice	Exploitation in the record	Fix	CWE (NVD)	KEV	Sources
CVE-2011-0609	Flash Player and Authplay	APSA11-01, 14 Mar; NVD 15 Mar	Targeted attacks in March through a .swf in an Excel e-mail attachment	Adobe's fix not opened	NVD-CWE-noinfo	2022-06-08	[12][13][54]
CVE-2011-0611	Flash Player, type confusion	NVD 13 Apr	Exploited in the wild in April 2011; NVD cites an Office document with an embedded .swf as the demonstration	Adobe's fix not opened	CWE-843	2022-03-03	[15][54]

CVE	Product and flaw	First notice	Exploitation in the record	Fix	CWE (NVD)	KEV	Sources
CVE-2011-1823	Android vold ("Gingerbreak"), privilege escalation	NVD 9 Jun	No 2011 date in the record; KEV-listed	not opened	CWE-190	2022-09-08	[69][54]
CVE-2011-1889	Forefront TMG 2010 Client, remote code execution	MS11-040, 14 Jun	No 2011 date in the record; KEV-listed	MS11-040	not checked	2022-03-03	[70][54]
CVE-2011-3192	Apache HTTP Server, Range-header denial of service	Advisory 24 Aug (final 31 Aug)	Attack tool circulating and in active use; NVD records exploitation in the wild in August	2.2.20; 2.2.21 improved the fix and added MaxRanges	CWE-400	not in KEV	[27][54]
CVE-2011-2005	Windows afd.sys, privilege escalation	MS11-080, 11 Oct	No 2011 date in the record; KEV-listed	MS11-080	not checked	2022-03-28	[71][54]
CVE-2011-3544	Oracle Java SE, Scripting component	NVD 19 Oct	No 2011 date in the record; KEV-listed	not opened	not checked	2022-03-03	[72][54]
CVE-2011-3402	Windows win32k TrueType font parsing	Advisory 2639658, 3 Nov; NVD 4 Nov	Exploited in the wild in November by Duqu	MS11-087, 13 Dec	NVD-CWE-noinfo	2025-10-06	[42][43][44][54]
CVE-2011-2462	Adobe Reader and Acrobat, U3D memory corruption	NVD 7 Dec	Exploited in the wild in December	Adobe's fix not opened	CWE-787	2022-06-08	[50][54]
CVE-2011-4862	telnetd encryption-key buffer overflow (FreeBSD 7.3 to 9.0, MIT krb5-appl, Heimdal, GNU inetutils)	NVD, December	Exploited in the wild in December	not opened	CWE-120	not in KEV	[75][54]
CVE-2011-4723	D-Link DIR-300	KEV	No date in the record	not opened	not checked	2022-09-08	[54]

Two Critical Windows network flaws had no exploitation in the record. MS11-058 of 9 August fixed a Windows DNS Server remote code execution flaw involving NAPTR records, and MS11-083 of 8 November fixed a TCP/IP remote code execution flaw reachable through a continuous flow of crafted UDP packets to a closed port on Vista, Server 2008, Windows 7 and Server 2008 R2 (Confirmed [74][73]).

In ATT&CK terms the document and plug-in flaws read as T1203 Exploitation for Client Execution and the kernel flaws as T1068 Exploitation for Privilege Escalation; neither is listed for a 2011 object, so the binding is this study's (Inferred). CVE-2011-1823 is an Android flaw and is not bound to ATT&CK for Mobile here (Inferred).

The denial-of-service class

Two 2011 disclosures described denial of service through crafted requests that exhaust server resources. Apache's advisory for CVE-2011-3192 says an attack tool was circulating and in active use against the Range header, that 2.2.20 fixed it and 2.2.21 improved the fix and added the MaxRanges directive, and that 1.3 was not affected (Confirmed [27]). CERT/CC's VU#903934, public on 28 December, described denial of service through hash collisions across language runtimes and web frameworks, and US-CERT alerted the same day; Microsoft's out-of-band MS11-100 of 29 December, rated Critical, fixed one publicly disclosed and three privately reported .NET Framework and ASP.NET flaws including CVE-2011-3414, "Collisions in HashTable May Cause DoS", and PHP's instance, CVE-2011-4885, was fixed in 5.3.9 (Confirmed [52][51][53]).

Microsoft's year in bulletins

MS11-001 was published on 11 January and MS11-100 on 29 December, out of band, and MS11-101 does not exist, so the year carried 100 bulletins by numbering (Confirmed [68][53]; the count is Inferred).

The year's CVE volume

A query of NVD by publication date returns 4,172 CVE records published during 2011, in four windows of 1,447, 1,149, 1,519 and 57 records; that is a query result by publication date, not a count of CVE-2011 ids (Confirmed [95]).

The KEV tail

The KEV catalog, version 2026.11.10, lists nine CVE-2011 entries (Confirmed [54]):

KEV dateAdded	CVE-2011 ids
2022-03-03	CVE-2011-0611, CVE-2011-1889, CVE-2011-3544
2022-03-28	CVE-2011-2005
2022-06-08	CVE-2011-0609, CVE-2011-2462
2022-09-08	CVE-2011-1823, CVE-2011-4723
2025-10-06	CVE-2011-3402

So 2011 exploitation is recorded mainly in NVD's "exploited in the wild" text and in vendor advisories, not in a catalog of the time, and two flaws NVD records as exploited in 2011, CVE-2011-3192 and CVE-2011-4862, are not in KEV (Confirmed [54][27][75]; Inferred for the reading).

Part 5: Duqu and Stuxnet in 2011 (summary)

The Stuxnet study is the home for Stuxnet, Duqu and Gauss, and it already records the 2011 press items: the January 2011 New York Times report, Iran's Passive Defense chief blaming Siemens, the United States and Israel on 16 April, and the Deputy Secretary of Defense's non-answer, all graded Reported there (Confirmed that the home study carries them [103]; the items are Reported). Symantec's W32.Stuxnet Dossier v1.4 of February 2011 says Stuxnet targeted five organizations, that 12,000 infections trace back to them, that the target was likely an industrial control system in Iran, where most infections were found, and that Symantec held 3,280 unique samples (Confirmed [55]). The home study records Kaspersky's finding that the first Gauss infections came in September and October 2011, mostly in Lebanon; Kaspersky was not reopened here (Reported [103]).

Duqu is the year's own entry. CrySyS Lab at the Budapest University of Technology and Economics published technical report v0.93, "Duqu: A Stuxnet-like malware found in the wild", on 14 October; it found Stuxnet code massively reused in targeted attacks and a new driver signed with a Taiwanese hardware manufacturer's certificate (Confirmed [39]; Demonstrated by the researchers' analysis). Symantec's W32.Duqu, version 1.0 of 18 October to version 1.4 of 23 November, says CrySyS alerted it on 14 October, that the first recorded attack came in early April 2011 with compile times suggesting November 2010, that infections were confirmed in six possible organizations in eight countries, that one delivery came through a Word document with a then-undisclosed kernel zero-day, and that new modules were downloaded on 18 October (Confirmed [40]). ICS-CERT's alert ICS-ALERT-11-291-01E said Duqu targeted neither industrial control systems nor their vendors, saw no evidence of a specific ICS threat and few infections as of 21 October, and listed the countries Symantec confirmed: France, the Netherlands, Switzerland, Ukraine, India, Iran (two), Sudan and Vietnam (Confirmed [41]).

Microsoft's Advisory 2639658 of 3 November covered the TrueType font parsing flaw CVE-2011-3402 and offered a workaround that denies access to T2EMBED.DLL; MS11-087, rated Critical for all supported Windows releases, fixed it on 13 December (Confirmed [42][44]). NVD published the CVE on 4 November, records it as exploited in the wild in November 2011 by Duqu through crafted font data, and lists NVD-CWE-noinfo; CISA added it to KEV on 6 October 2025 (Confirmed [43][54]). ATT&CK's S0038 Duqu lists no group, 21 Enterprise techniques and three ICS techniques (Confirmed [45]; Demonstrated [100]). No 2011 primary opened here names a state behind Duqu; the Stuxnet link is a code-reuse finding, not an attribution (Inferred [39][45]). The United States-attributed threat actors study carries Duqu in its table of objects without a named sponsor (Confirmed [103]).

Part 6: the state and espionage record

Night Dragon

McAfee's white paper "Global Energy Cyberattacks: Night Dragon", dated 10 February, says that starting in November 2009 coordinated covert and targeted attacks hit global oil, energy and petrochemical companies through social engineering, spear-phishing, Windows exploits, Active Directory compromise and remote administration tools (Confirmed [2]). McAfee says the tools, techniques and network activity originated primarily in China, that many actors took part, and that it identified one individual who provided command and control infrastructure; attackers working from several locations in China used servers on purchased US hosting and compromised servers in the Netherlands, against companies and executives in Kazakhstan, Taiwan, Greece and the United States (Confirmed [2]). That attributes the activity to China-based actors, not to a named state body (Inferred from [2]). ATT&CK's C0002 Night Dragon was first seen in November 2009 and last seen in February 2011, says researchers assessed a China-based group, associates no group object, and lists 29 techniques and the software ASPXSpy, PsExec, at, gsecdump and zwShell (Confirmed [1]; Demonstrated [100]). The home is China-attributed threat actors, which carries Night Dragon in its campaign table (Confirmed [103]).

APT1 in 2011

Mandiant's APT1 report of February 2013 says APT1 compromised at least 17 new victims in 10 industries in the first month of 2011, and that Mandiant confirmed 1,905 instances of APT1 actors logging into their attack infrastructure over Remote Desktop between January 2011 and January 2013 from 832 IP addresses, with over 97 percent of the logins coming from Shanghai-registered addresses (Confirmed [56]). Mandiant says APT1 is likely government-sponsored and that PLA Unit 61398 is similar to APT1 in mission, capabilities and resources and is located in the same area; that is the vendor's assessment (Confirmed that Mandiant says so [56]). ATT&CK's G0006 APT1, aliases Comment Crew, Comment Group and Comment Panda, attributes the group to the 2nd Bureau of the PLA General Staff Department's 3rd Department, Unit 61398 (Confirmed [57]). On 1 May 2014 a grand jury in the Western District of Pennsylvania indicted five officers of 3PLA, Second Bureau, Third Office, MUCD 61398, on 31 counts, alleging a conspiracy to penetrate six American companies and steal e-mail and nuclear plant design specifications; which counts fall in 2011 was not checked (Confirmed as charged [58]; not checked for 2011). Mandiant's report also quotes Representative Mike Rogers at the House intelligence committee's open hearing of 4 October 2011 urging the United States and its allies to confront Beijing over economic espionage; that is seen only as Mandiant quotes it (Reported [56]). The home is China-attributed threat actors (Confirmed [103]).

The Gmail campaign

Google said on 1 June that it had uncovered a campaign to collect passwords, likely through phishing, that appeared to originate from Jinan, China, and affected the personal Gmail accounts of hundreds of users, including senior US government officials, Chinese political activists, officials in several Asian countries (mainly South Korea), military personnel and journalists; the attackers apparently used the stolen passwords to change forwarding and delegation settings (Confirmed [22]). US-CERT's alert of 2 June said the campaign targeted US government and military officials' Gmail accounts with spoofed senders and a fake login page and that Google had disrupted it (Confirmed [23]). Google names a city, not a state, and no ATT&CK object records the campaign, so no group id is bound (Confirmed [22]; Demonstrated [100]).

Iran and the financial sector

A Southern District of New York indictment dated 21 January 2016 charges seven Iranians over DDoS attacks on the US financial sector and other companies from 2011 through 2013, and says ITSecTeam and Mersad worked on behalf of the Iranian Government, including the IRGC; these are allegations (Confirmed as charged [59]). The homes are the 2016 chronicle and Iran-attributed threat actors (Confirmed [103]). No ATT&CK group object for this activity was found in what was opened, so no group id is bound (Demonstrated [100]).

Belgacom, Sykipot and the objects written later

The Hacker and the State study is the home for the Belgacom intrusion, which it dates as staged in 2010 and 2011 and surging by December 2011, graded Reported because it rests on journalism built on leaked documents (Confirmed that the study carries it [103]; Reported). Several ATT&CK objects reach back to 2011 only through later reporting. S0018 Sykipot has been used in spearphishing since about 2007, mainly against US victims, and one variant hijacks smart cards; the date of the AlienVault post ATT&CK cites was not checked (Confirmed [61]; not checked for the date). G0032 Lazarus Group is described as North Korean state-sponsored and attributed to the Reconnaissance General Bureau, active since at least 2009, with malware ATT&CK correlates to operations including Ten Days of Rain, whose 2011 date was not checked (Confirmed [62]; not checked for the date). The home is North Korea-attributed threat actors (Confirmed [103]). G0004 Ke3chang has been active since at least 2010 and is attributed to actors operating out of China; no 2011-dated event was checked (Confirmed [63]). S0143 Flame has been used since at least 2010, largely in the Middle East, and was reported in May 2012 (Confirmed [64]). ATT&CK describes G0041 Strider, G0081 Tropic Trooper and G0124 Windigo (with its S0377 Ebury) as active since 2011, and campaign C0016 Operation Dust Storm as running from January 2010 to February 2016 (Confirmed [66]; Demonstrated [100]). None is tied to a dated 2011 event in the record opened here, so none is in this study's Navigator layer (Inferred).

Defense strategy

The DoD Strategy for Operating in Cyberspace of July 2011 sets five strategic initiatives, the first to treat cyberspace as an operational domain, and says successful penetrations have led to the loss of thousands of files from US, allied and industry networks; the "24,000 files" figure from the Deputy Secretary's speech was not checked (Confirmed [65]; not checked for the figure).

Part 7: consumer and corporate breaches

NASDAQ OMX

NASDAQ OMX's 10-K, filed on 24 February, says that in February 2011 the company announced it had detected suspicious files on its US servers, removed them, and found no evidence that customer information was accessed (Confirmed [3]).

Epsilon

Alliance Data's 8-K of 6 April says its Epsilon unit detected "late last week" an unauthorized entry into its e-mail system that exposed e-mail addresses and/or names of customers of a subset of clients, about 2 percent of its client base, and states that no personally identifiable information was compromised (Confirmed as the company's account [14]).

Sony

Sony's PlayStation Blog said on 26 April that an illegal intrusion into PlayStation Network and Qriocity between 17 and 19 April exposed names, addresses, e-mail addresses, birthdates, logins and passwords and PSN IDs, and possibly profile data, purchase history, security answers and card data; Sony had no evidence that card data was taken but could not rule it out, turned the services off and engaged an outside security firm (Confirmed [17]). Sony's 6-K of 2 May says a criminal cyber-attack on the San Diego data center led Sony Network Entertainment International to turn off PSN and Qriocity, announces phased restoration, and creates a Chief Information Security Officer post (Confirmed [19]). Its 6-K of 3 May says Sony Online Entertainment found that personal information from about 24.6 million SOE accounts may have been stolen on 16 and 17 April, along with about 12,700 non-US card numbers and about 10,700 direct-debit records from an outdated 2007 database (Confirmed [18]). Sony's records name no intruder and describe no technique, so no ATT&CK id is bound (Inferred).

Steam

Valve's message of 10 November says the Steam forums were defaced on 6 November and that intruders accessed a Steam database holding user names, hashed and salted passwords, purchases, e-mail and billing addresses and encrypted card information, with no evidence that card numbers were taken (Confirmed [48]).

Part 8: hacktivism and the courts (summary)

The home for Anonymous, LulzSec, AntiSec, HBGary and Stratfor is Part 3 of Four Books on Cybercrime (Confirmed [103]). This chronicle records the 2011 dates. The charges the FBI announced on 6 March 2012 allege that Internet Feds members hacked HBGary Inc. and HBGary Federal (data on 80,000 user accounts) and Fox (data on more than 70,000 X-Factor contestants) between December 2010 and May 2011, and that LulzSec, formed in May 2011, hacked PBS, Sony Pictures Entertainment (data on about 100,000 users) and Bethesda Softworks (about 200,000 users) (Reported, as alleged [4]). The FBI's Los Angeles office said on 22 September that Sony Pictures' systems were compromised from about 27 May to 2 June by LulzSec, that Cody Kretsinger was arrested that day on a sealed indictment returned on 2 September, and that the indictment alleges SQL injection (Confirmed that the FBI says so; LulzSec's role is as charged [21]).

On 19 July the FBI arrested 14 people on a Northern District of California indictment over the 6 to 10 December 2010 DDoS on PayPal that Anonymous called "Operation Avenge Assange", plus two on separate complaints, one over the 21 June intrusion into the Tampa Bay InfraGard site and one over theft of AT&T business information; more than 35 search warrants were executed, and the UK Metropolitan Police made one arrest and the Dutch National Police four the same day (Confirmed as charged [24]). US-CERT's TA11-200A, also of 19 July, gave security recommendations in response to recent well-publicized intrusions into government and private networks without naming a group (Confirmed [25]). Hector Xavier Monsegur ("Sabu") pleaded guilty on 15 August to a 12-count information including charges for the HBGary, Sony Pictures, Fox, InfraGard and PBS hacks; the plea was unsealed on 6 March 2012 (Confirmed [4]). Jeremy Hammond was charged in March 2012 over the December 2011 Stratfor hack, alleged to affect about 860,000 subscribers, with about 60,000 card numbers stolen and more than USD 700,000 in unauthorized charges (Reported, as alleged [4]).

Part 9: botnets and takedowns

Rustock

Microsoft wrote on 17 March that Operation b107 had taken the Rustock spam botnet offline on 16 March under a court action in the Western District of Washington, with command servers seized from five hosting providers alongside the US Marshals (Confirmed [9]). Microsoft estimated about one million infected computers and up to 30 billion spam e-mails a day at times; these are the company's estimates (Confirmed that Microsoft says so [9]).

Coreflood

The Justice Department and FBI announced on 13 April a civil complaint against 13 John Doe defendants in the District of Connecticut for wire fraud, bank fraud and illegal interception, a seizure warrant for 29 domains, search warrants for servers, and a temporary restraining order that let the government respond to infected US computers to stop Coreflood running (Confirmed [16]). The release's headline says more than two million computers were infected with keylogging software, and its text describes a botnet of hundreds of thousands of computers (Confirmed [16]).

Kelihos

Microsoft's Operation b79 took down Kelihos, which it described as "Waledac 2.0": it sought an ex parte restraining order in the Eastern District of Virginia on 22 September, took the botnet down on 26 September, and announced on 27 September its first botnet civil case naming a defendant, Dominique Alexander Piatti and dotFREE Group SRO, the registrant of the cz.cc domain, with John Does 1 to 22 (Confirmed [34]). Microsoft estimated about 41,000 infected computers sending up to 3.8 billion spam e-mails a day (Confirmed that Microsoft says so [34]). Kelihos returned to court in 2017, as the 2017 chronicle records (Confirmed [103]).

Operation Ghost Click

The US Attorney for the Southern District of New York charged six Estonian nationals and one Russian national on 9 November over DNSChanger malware alleged to have re-routed more than four million computers in over 100 countries, at least 500,000 in the United States including NASA's, for click hijacking and advertising replacement fraud worth at least USD 14 million; the malware also blocked anti-virus and operating system updates (Confirmed as charged [46]). Six were arrested in Estonia on 8 November and one remained at large (Confirmed [46]). The FBI's account says the scheme ran from 2007 and that the rogue DNS servers were replaced with clean ones (Confirmed [47]).

Morto

Microsoft's encyclopedia says Worm:Win32/Morto.A spreads by trying to compromise administrator passwords for Remote Desktop connections on a network and succeeds against weak passwords (Confirmed [67]). The page gives no outbreak date, and the library's ATT&CK data has no Morto object; T1110 Brute Force and T1021.001 Remote Desktop Protocol are this study's mapping (Confirmed [67]; Demonstrated [100]; Inferred for the mapping).

Part 10: industrial systems

Duqu was the year's industrial question, and ICS-CERT answered it: no ICS or ICS vendor targeting (Confirmed [41]). ATT&CK nonetheless lists three ICS techniques for S0038 (Part 13), which this study binds as ATT&CK lists them and flags against ICS-CERT's finding (Confirmed [45][41]). Night Dragon's victims were energy companies; McAfee describes intrusions through spear-phishing, Windows exploits and Active Directory, and ATT&CK's C0002 record says the actors searched for information on oil and gas field production systems and collected data from SCADA systems, though ATT&CK lists no ICS technique for C0002 (Confirmed [2][1]; Demonstrated [100]).

The ICS-CERT Monitor of January 2012 records two December 2011 incidents. At a US chemical company a business-network infection, suspected exfiltration and persistent, non-opportunistic malware led ICS-CERT to send an on-site team; at a rail company, in early December, redundant switchgear communications received erroneous SNMP traffic with spoofed source addresses that caused intermittent loss of backup communications, with primary communications and control unaffected and no targeted attack (Confirmed [76]). The same Monitor quotes Threatpost of 12 December that DHS warned SCADA operators about internet-facing systems after a hack of a Texas community's water and sewer infrastructure; the Texas event was not opened at a primary (Reported [76]). None of these incidents is bound to an ATT&CK id (Inferred).

Part 11: law, policy and standards

Strategy and organization

The White House published the International Strategy for Cyberspace in May; it sets seven policy priorities and says the United States will respond to hostile acts in cyberspace as it would to any other threat, reserving the right to use all necessary means, diplomatic, informational, military and economic (Confirmed [20]). The White House Cybersecurity Legislative Proposal of 12 May proposed a national data breach reporting standard to replace 47 state laws, RICO coverage and mandatory minimum sentences for intrusions into critical infrastructure, and voluntary DHS assistance and information sharing (Confirmed [77]). The DoD Strategy for Operating in Cyberspace followed in July (Confirmed [65]). Executive Order 13587, signed on 7 October (76 FR 63811), ordered structural reforms to secure classified networks and to share and safeguard classified information responsibly (Confirmed [91]). The UK Cabinet Office published the UK Cyber Security Strategy on 25 November (Confirmed [92]).

Regulation

The SEC's Division of Corporation Finance issued CF Disclosure Guidance Topic No. 2, Cybersecurity, on 13 October; it asks registrants to disclose material cyber risks and incidents in risk factors, MD&A, the description of business, legal proceedings, financial statements and disclosure controls, without details that would compromise security (Confirmed [38]). The home is E-Commerce Threats (Confirmed [103]). In the FTC's Facebook settlement of 29 November, on an eight-count deception complaint, Facebook agreed to set up a privacy program and independent audits every two years for 20 years (Confirmed [93]). An OMB memorandum from the Federal CIO of 8 December established FedRAMP, with standardized cloud security requirements, third-party assessment and a DHS, DoD and GSA Joint Authorization Board (Confirmed [94]).

Standards and frameworks

NIST published SP 800-39, Managing Information Security Risk, in March; SP 800-137, Information Security Continuous Monitoring, and SP 800-145, The NIST Definition of Cloud Computing, in September; and SP 800-144, Guidelines on Security and Privacy in Public Cloud Computing, and SP 800-63-1, Electronic Authentication Guideline, in December (Confirmed [78][79][80][81][82]). SP 800-63-1 superseded SP 800-63 of 2006 and was withdrawn on 29 August 2013 in favor of SP 800-63-2 (Confirmed [82]). The IETF published RFC 6176 and RFC 6125 in March, RFC 6265 on HTTP cookies in April (obsoleting RFC 2965), RFC 6101 in August, and RFC 6376 on DKIM signatures in September (obsoleting RFC 4871 and RFC 5672) (Confirmed [83][84][85][86][87]).

The 2011 CWE/SANS Top 25 is dated 27 June (version 1.0.3 on 13 September) and was scored with CWSS; its top ten are CWE-89, CWE-78, CWE-120, CWE-79, CWE-306, CWE-862, CWE-798, CWE-311, CWE-434 and CWE-807 (Confirmed [88]). CWE Version 2.0 was released on 27 June alongside the Top 25, CWSS 0.8 and CWRAF 0.8, and CWE 2.1 followed on 13 September (Confirmed [89]).

Part 12: the defender view

Trust stores needed an owner. Every 2011 CA failure ended with a vendor untrusting certificates or roots, and Microsoft warned that revocation checks can fail open (Confirmed [6][29][49]). Certificate Analysis and Certificate Pinning are the matching D3FEND pages, and Certificate Rotation covers replacing certificates issued by a failed CA; the library links no countermeasure to T1588.004 (Demonstrated [101]; Inferred for the pairing). The certificate trust incident response reference carries the playbook side (Inferred).

Pinning likely worked where it existed. Chrome detected the DigiNotar certificate used against Google users, and Chrome 13 pinned Google properties (Confirmed [90][28]; Inferred for the link). M1041 Encrypt Sensitive Information does not cover pinning, so the control is D3FEND's Certificate Pinning (Inferred).

Second factors needed their own incident plan. RSA told customers to strengthen SecurID deployments, and EMC replaced tokens (Confirmed [10][11]). Multi-factor Authentication, One-time Password, Credential Rotation and Reissue Credential are the library's D3FEND pages that fit, and M1032 Multi-factor Authentication the ATT&CK mitigation (Demonstrated [102]; Inferred for the pairing).

Documents needed filtering. The March Flash flaw arrived inside an Excel attachment; NVD records the April Flash flaw as demonstrated with an Office document and gives no vector for the Reader flaw (Confirmed [12][15][50]). Email Filtering, File Analysis and Dynamic Analysis are linked to T1566.001 in the library's data, and the exploit mitigations Process Segment Execution Prevention, Segment Address Offset Randomization and Stack Frame Canary Validation to T1203 and T1068 (Demonstrated [101]). M1050 Exploit Protection and M1051 Update Software are the ATT&CK mitigations (Inferred).

Mail settings were persistence. The Gmail attackers changed forwarding and delegation (Confirmed [22]). The library links Application Configuration Hardening and Restore Configuration to T1114.003 (Demonstrated [101]).

Weak remote passwords were an entry point. Morto guessed weak Remote Desktop administrator passwords (Confirmed [67]). Strong Password Policy, Account Locking and Remote Terminal Session Detection are the library's D3FEND pages that fit, and M1027 Password Policies and M1032 Multi-factor Authentication the ATT&CK mitigations (Demonstrated [101]; Inferred for the pairing).

Takedown was a legal tool. Rustock and Kelihos fell to civil orders, Coreflood to a government order to stop running, and DNSChanger to arrests and clean replacement DNS servers (Confirmed [9][34][16][47]). The incident response reference carries the coordination side (Inferred).

Disclosure was now governance. The SEC's guidance followed a year of 8-K and 6-K breach filings (Confirmed [38][10][14][18][19][26]). The GRC and compliance reference covers disclosure duties (Inferred).

Part 13: MITRE mappings

No 2011 record opened here carries an ATT&CK id; every binding below is a later mapping (Inferred). Every Enterprise binding is either a technique ATT&CK lists for an object it ties to 2011 (C0002 Night Dragon, S0038 Duqu, G0006 APT1) or this study's mapping of a behavior a source describes (Inferred). Every id was checked against the library's data files (`data/attack/technique_profiles.jsonl`, `campaign_profiles.jsonl`, `software_to_technique.jsonl`, `group_to_technique.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl`, `data/attack/ics/` and `data/weaknesses/`) and against the generated pages under `mitre/` on 12 and 13 November 2026 (Demonstrated [100][101][102]). Names and tactics are those of ATT&CK v20.0 as the library carries them, including the v20.0 tactics stealth and defense-impairment and the v20.0 id T1685 Disable or Modify Tools (Demonstrated [100]).

The Basis column says how strong each tie is, as in the 2016 chronicle. **Listed** means ATT&CK itself lists the id for the object. **Described** means a primary source describes the behavior and this study assigns the id. **Reported** means only a Reported source describes it. **Inferred** means the mapping rests on this study's reading. Two caveats apply to the Listed rows: APT1's techniques come from ATT&CK's group record across years of reporting, and only the eight techniques the record opened here names for APT1 are bound, not all 23 the library's data carries; and Duqu's three ICS techniques sit against ICS-CERT's finding that Duqu did not target ICS (Confirmed [57][41]; Demonstrated [100]).

ATT&CK Enterprise techniques

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1583.004	Server	resource-development	Listed (C0002)	Night Dragon's purchased US hosting (McAfee, 10 Feb)	[1][2]
T1584.004	Server	resource-development	Listed (C0002)	Night Dragon's compromised servers in the Netherlands (McAfee, 10 Feb)	[1][2]
T1588.001	Malware	resource-development	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1588.002	Tool	resource-development	Listed (C0002)	Night Dragon's PsExec, at and gsecdump	[1]
T1608.001	Upload Malware	resource-development	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1588.004	Digital Certificates	resource-development	Described	Fraudulent Comodo certificates (15 Mar); fraudulent DigiNotar certificates (detected 19 Jul, public 29 Aug)	[5][6][26][28][96]
T1598.003	Spearphishing Link	reconnaissance	Described	Gmail campaign's fake login page (US-CERT, 2 Jun)	[23][22]
T1190	Exploit Public-Facing Application	initial-access	Listed (C0002); Described	Night Dragon; SQL injection against Sony Pictures, as the indictment alleges (27 May to 2 Jun); the telnetd flaw CVE-2011-4862 (Dec; match Inferred)	[1][21][75]
T1133	External Remote Services	persistence, initial-access	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1566.001	Spearphishing Attachment	initial-access	Listed (G0006); Described	APT1; Flash in an Excel e-mail attachment (APSA11-01, 14 Mar; RSA link not checked); Duqu by Word document (Symantec)	[57][12][40]
T1566.002	Spearphishing Link	initial-access	Listed (C0002, G0006)	Night Dragon; APT1	[1][57]
T1078	Valid Accounts	stealth, persistence, privilege-escalation, initial-access	Listed (C0002, S0038); Described	Night Dragon; Duqu; the compromised Comodo RA account (15 Mar); stolen Gmail passwords (1 Jun)	[1][45][5][22]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1078.002	Domain Accounts	stealth, persistence, privilege-escalation, initial-access	Listed (C0002)	Night Dragon's Active Directory compromise (McAfee)	[1][2]
T1204.001	Malicious Link	execution	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1059.003	Windows Command Shell	execution	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1053.005	Scheduled Task	execution, persistence, privilege-escalation	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1203	Exploitation for Client Execution	execution	Described	CVE-2011-0609 (Mar), CVE-2011-0611 (Apr), CVE-2011-3402 through a Word document (Duqu, from Apr), CVE-2011-2462 (Dec); CVE-2011-3544 in KEV (match Inferred)	[12][15][40][43][50][72]
T1543.003	Windows Service	persistence, privilege-escalation	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1068	Exploitation for Privilege Escalation	privilege-escalation	Described	Duqu's kernel zero-day CVE-2011-3402 (Nov); afd.sys CVE-2011-2005 in KEV (match Inferred)	[40][43][71][54]
T1134	Access Token Manipulation	stealth, privilege-escalation	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1055.001	Dynamic-link Library Injection	stealth, privilege-escalation	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1055.012	Process Hollowing	stealth, privilege-escalation	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1027.002	Software Packing	stealth	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1027.013	Encrypted/Encoded File	stealth	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1218.007	Msiexec	stealth	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1112	Modify Registry	defense-impairment, persistence	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1685	Disable or Modify Tools	defense-impairment	Listed (C0002); Described	Night Dragon; DNSChanger blocked anti-virus and operating system updates, as charged (9 Nov)	[1][46]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1553.002	Code Signing	defense-impairment	Described	Duqu's driver signed with a Taiwanese maker's certificate (CrySyS, 14 Oct); not in S0038's ATT&CK mapping	[39]
T1110	Brute Force	credential-access	Inferred	Morto guessed Remote Desktop administrator passwords (date not in the record)	[67]
T1110.002	Password Cracking	credential-access	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1003.001	LSASS Memory	credential-access	Listed (G0006)	APT1 (ATT&CK object)	[57]
T1003.002	Security Account Manager	credential-access	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1056.001	Keylogging	collection, credential-access	Listed (S0038); Described	Duqu; Coreflood's keylogging software (13 Apr)	[45][16]
T1557	Adversary-in-the-Middle	credential-access, collection	Described	Attempted SSL man-in-the-middle attacks on Google users primarily in Iran with a DigiNotar certificate (29 Aug)	[28][29]
T1087.001	Local Account	discovery	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1010	Application Window Discovery	discovery	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1057	Process Discovery	discovery	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1016	System Network Configuration Discovery	discovery	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1049	System Network Connections Discovery	discovery	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1083	File and Directory Discovery	discovery	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1033	System Owner/User Discovery	discovery	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1021.001	Remote Desktop Protocol	lateral-movement	Listed (G0006); Described	APT1 (ATT&CK object); Morto (match Inferred)	[57][67]
T1021.002	SMB/Windows Admin Shares	lateral-movement	Listed (S0038)	Duqu (ATT&CK object)	[45]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1550.002	Pass the Hash	lateral-movement	Listed (C0002, G0006)	Night Dragon; APT1	[1][57]
T1005	Data from Local System	collection	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1074.001	Local Data Staging	collection	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1074.002	Remote Data Staging	collection	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1114.001	Local Email Collection	collection	Listed (C0002, G0006)	Night Dragon; APT1	[1][57]
T1114.002	Remote Email Collection	collection	Listed (G0006)	APT1 (ATT&CK object)	[57]
T1114.003	Email Forwarding Rule	collection	Described	Gmail forwarding settings changed with stolen passwords (1 Jun)	[22]
T1560.001	Archive via Utility	collection	Listed (G0006)	APT1 (ATT&CK object)	[57]
T1560.003	Archive via Custom Method	collection	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1071	Application Layer Protocol	command-and-control	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1071.001	Web Protocols	command-and-control	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1001.002	Steganography	command-and-control	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1573.001	Symmetric Cryptography	command-and-control	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1572	Protocol Tunneling	command-and-control	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1090.001	Internal Proxy	command-and-control	Listed (S0038)	Duqu (ATT&CK object)	[45]
T1008	Fallback Channels	command-and-control	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1105	Ingress Tool Transfer	command-and-control	Listed (C0002)	Night Dragon (ATT&CK object)	[1]
T1219	Remote Access Tools	command-and-control	Listed (C0002)	Night Dragon's remote administration tools (McAfee)	[1][2]
T1568	Dynamic Resolution	command-and-control	Listed (C0002)	Night Dragon (ATT&CK object)	[1]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1498	Network Denial of Service	impact	Described	The PayPal DDoS (Dec 2010), charged 19 Jul 2011; the 2011 to 2013 financial-sector DDoS, as charged in 2016	[24][59]
T1499.004	Application or System Exploitation	impact	Described	Apache Range-header attack tool in active use (24 Aug)	[27]
T1491.002	External Defacement	impact	Described	Steam forums defaced (6 Nov)	[48]
T1657	Financial Theft	impact	Reported	Over USD 700,000 in unauthorized charges on Stratfor subscribers' cards, as alleged (Dec)	[4]

Left out on purpose: any technique for the Rustock and Kelihos spam, which ATT&CK does not model as a technique [9][34]; any technique for the Sony, Epsilon, NASDAQ OMX and Lockheed Martin incidents, whose primaries describe no technique [17][14][3][60]; any technique tying RSA to CVE-2011-0609, which was not checked [10][12]; the HBGary and other LulzSec intrusions beyond Sony Pictures, which rest on charges graded Reported and whose method the home study carries [4][103]; BEAST, the hash-collision flaws and the Windows network flaws, which have no exploitation in the record [37][52][73][74]; CVE-2011-1823, an Android flaw, from ATT&CK for Mobile [69]; and the techniques of Sykipot, Lazarus Group, Ke3chang, Flame, Strider, Tropic Trooper, Windigo and Operation Dust Storm, none tied to a dated 2011 event in the record [61][62][63][64][66].

ATT&CK for ICS

The library has no generated pages for ICS techniques, so the ids are plain text; names and tactics are those in `data/attack/ics/` (Demonstrated [100][102]). No ICS layer is saved for this chronicle.

Id	Name (ATT&CK for ICS v20.0)	Tactic(s)	Object	Basis	Dated event or report	Sources
T0811	Data from Information Repositories	collection	S0038 Duqu	Listed	Duqu (ATT&CK object); ICS-CERT found no ICS targeting (Oct)	[45][41]
T0893	Data from Local System	collection	S0038 Duqu	Listed	Duqu (ATT&CK object); ICS-CERT found no ICS targeting (Oct)	[45][41]
T0882	Theft of Operational Information	impact	S0038 Duqu	Listed	Duqu (ATT&CK object); ICS-CERT found no ICS targeting (Oct)	[45][41]

The December 2011 chemical and rail incidents and the Texas water report are not bound: the chemical record describes a business-network infection, the rail event was not an attack, and the water event is Reported (Confirmed [76]; Inferred).

ATT&CK groups, software and campaigns

Object	Id	Binding	Sources
Night Dragon	C0002	Bound: last seen February 2011, published 10 February; all 29 techniques in the layer	[1][2]
ASPXSpy, PsExec, at, gsecdump, zwShell	S0073, S0029, S0110, S0008, S0350	Bound through C0002, whose software ATT&CK lists	[1][100]
Duqu	S0038	Bound: first recorded attack April 2011, disclosed October; all 21 Enterprise techniques in the layer, three ICS techniques in the table above	[45][39][40]
APT1	G0006	Bound with a caveat: Mandiant's 2013 report records APT1 activity from January 2011; eight of its 23 techniques in the layer	[57][56]
Stuxnet	S0603	Context: Symantec's dossier v1.4 (February 2011); the home study binds it	[55][103]
Sykipot	S0018	Context: used since about 2007; the 2011 date of the post ATT&CK cites was not checked	[61]
Lazarus Group	G0032	Context: active since at least 2009; the 2011 date of Ten Days of Rain was not checked	[62]
Ke3chang	G0004	Context: active since at least 2010; no 2011 event checked	[63]
Flame	S0143	Context only: active since at least 2010, reported in 2012	[64]
Strider, Tropic Trooper, Windigo and Ebury	G0041, G0081, G0124, S0377	Context only: ATT&CK says active since 2011	[66][100]
Operation Dust Storm	C0016	Context only: January 2010 to February 2016	[100]

The library's ATT&CK data has no object for the Comodo or DigiNotar attackers, the RSA intruders, the Gmail campaign, Rustock, Kelihos, Coreflood, DNSChanger, Morto, Anonymous, LulzSec or the 2011 to 2013 DDoS (Demonstrated [100]).

CWE and CAPEC

The CWE column names the source of each id. Names are those in the library's CWE and CAPEC data, and every CAPEC listed has a page under `/mitre/capec/` (Demonstrated [101][102]). The library has no per-CWE generated pages, so CWE ids are plain text; the CWE reference is the library's entry point.

CWE	Weakness (library name)	Basis	2011 record	CAPEC
CWE-326	Inadequate Encryption Strength	NVD [37][98]	BEAST, CVE-2011-3389 (6 Sep)	None assigned (the library relates CAPEC-112, CAPEC-192 and CAPEC-20; none is specific to BEAST)
CWE-787	Out-of-bounds Write	NVD	Reader U3D, CVE-2011-2462 (Dec)	None (the library relates none)

CWE	Weakness (library name)	Basis	2011 record	CAPEC
CWE-843	Access of Resource Using Incompatible Type	NVD	Flash, CVE-2011-0611 (Apr)	None (the library relates none)
CWE-190	Integer Overflow or Wraparound	NVD	Android vold, CVE-2011-1823 (Jun)	CAPEC-92 Forced Integer Overflow, which the library relates
CWE-400	Uncontrolled Resource Consumption	NVD	Apache Range header, CVE-2011-3192 (Aug)	None assigned (the library relates CAPEC-147, CAPEC-227 and CAPEC-492; none is specific to this flaw)
CWE-120	Buffer Copy without Checking Size of Input	NVD; 2011 Top 25 rank 3	telnetd, CVE-2011-4862 (Dec)	CAPEC-100 Overflow Buffers, which the library relates
NVD-CWE-noinfo	(as NVD lists it)	NVD	Flash CVE-2011-0609; Windows TrueType CVE-2011-3402	None
CWE-295	Improper Certificate Validation	Study's pairing	The Comodo, DigiNotar and DigiCert Sdn. Bhd. failures (Inferred)	CAPEC-459 Creating a Rogue Certification Authority Certificate, the closest pattern to the 2011 CA cases, which the library and CAPEC relate to CWE-295, CWE-327 and CWE-290 [97]; CAPEC-475 Signature Spoofing by Improper Validation
CWE-89, CWE-78, CWE-79, CWE-306, CWE-862, CWE-798, CWE-311, CWE-434, CWE-807	Improper Neutralization of Special Elements used in an SQL Command; Improper Neutralization of Special Elements used in an OS Command; Improper Neutralization of Input During Web Page Generation; Missing Authentication for Critical Functionality; Missing Authorization; Use of Hard-coded Credentials; Missing Encryption of Sensitive Data; Unrestricted Upload of File with Dangerous Type; Reliance on Untrusted Inputs in a Security Decision	2011 Top 25 ranks 1, 2 and 4 to 10	CWE-89 fits the SQL injection the Sony Pictures indictment alleges (Inferred); the rest are bound to no 2011 event	CAPEC-66 SQL Injection; CAPEC-88 OS Command Injection; CAPEC-63 Cross-Site Scripting (XSS); CAPEC-1 Accessing Functionality Not Properly Constrained by ACLs, as the library relates them
none bound	(spearphishing)	Library data	APSA11-01's Excel attachment; Duqu's Word document; Night Dragon; APT1; the Gmail fake login page	CAPEC-163 Spear Phishing (on T1566.001, T1566.002 and T1598.003)
none bound	(adversary in the middle)	Library data	DigiNotar man-in-the-middle in Iran	CAPEC-94 Adversary in the Middle (AiTM) (on T1557)

CWE	Weakness (library name)	Basis	2011 record	CAPEC
none bound	(code signing)	Library data	Duqu's signed driver	CAPEC-68 Subvert Code-signing Facilities; CAPEC-206 Signing Malicious Code; CAPEC-473 Signature Spoof (on T1553.002)
none bound	(credentials)	Library data	Night Dragon; APT1; Comodo's RA account	CAPEC-55 Rainbow Table Password Cracking (on T1110.002); CAPEC-644 Use of Captured Hashes (Pass The Hash) (on T1550.002); CAPEC-555 Remote Services with Stolen Credentials (on T1133 and T1114.002); CAPEC-560 Use of Known Domain Credentials (on T1078)
none bound	(brute force)	Library data	Morto	CAPEC-112 Brute Force (on T1110)
none bound	(keylogging)	Library data	Coreflood; Duqu	CAPEC-568 Capture Credentials via Keylogger (on T1056.001)
none bound	(admin shares)	Library data	Duqu	CAPEC-561 Windows Admin Shares with Stolen Credentials (on T1021.002)
none bound	(defense impairment)	Library data	DNSChanger; Night Dragon	CAPEC-571 and CAPEC-578 (on T1685)

D3FEND countermeasures

The technique-to-countermeasure links come from the library's D3FEND data; pairing them with the 2011 record is this study's reading (Demonstrated [101]; Inferred). Every page exists under `/mitre/d3fend/` (Demonstrated [102]).

Technique or event from the record	D3FEND countermeasures (D3FEND tactic)	2011 analogue
T1588.004, T1557 (certificate abuse)	Certificate Pinning [99] and Certificate Analysis (study's pairing; the library links no countermeasure to T1588.004); Certificate Rotation (study's pairing)	Comodo [5]; DigiNotar [28]; Chrome's pins [90] (Inferred)
T1557	Network Traffic Signature Analysis (Detect); Protocol Metadata Anomaly Detection (Detect); Network Traffic Filtering (Isolate)	The DigiNotar man-in-the-middle in Iran [28]
T1566.001	Email Filtering (Isolate); File Analysis (Detect); Dynamic Analysis (Detect)	Flash in an Excel attachment [12]; Duqu's Word document [40]

Technique or event from the record	D3FEND countermeasures (D3FEND tactic)	2011 analogue
T1203, T1068	Process Segment Execution Prevention (Harden); Segment Address Offset Randomization (Harden); Stack Frame Canary Validation (Harden); Shadow Stack Comparisons (Detect); Memory Boundary Tracking (Detect)	The exploited Flash, Reader and kernel flaws [13][15][43][50]; no 2011 source opened here names these controls (Inferred)
T1078, T1110.002 (stolen or cracked credentials)	Multi-factor Authentication (Harden); One-time Password (Harden); Credential Rotation (Harden); Reissue Credential (Restore); Credential Revocation (Evict); Strong Password Policy (Harden); Account Locking (Evict)	Comodo's RA account [5]; Night Dragon [1]; SecurID remediation [11] (Inferred for SecurID)
T1114.003	Application Configuration Hardening (Harden); Restore Configuration (Restore)	Gmail forwarding changes [22]
T1021.001	Remote Terminal Session Detection (Detect); Session Termination (Evict)	Morto [67] (Inferred)
T1056.001	Input Device Analysis (Detect)	Coreflood [16]; Duqu [45]
T1190	Inbound Traffic Filtering (Isolate); Database Query String Analysis (Detect); Client-server Payload Profiling (Detect)	SQL injection at Sony Pictures, as alleged [21]; Night Dragon [1]
T1105, T1071.001	Outbound Traffic Filtering (Isolate); Relay Pattern Analysis (Detect)	Night Dragon's command and control [2]
T1491.002	Network Resource Access Mediation (Isolate)	Steam forum defacement [48]
T1543.003	System Configuration Permissions (Harden)	Duqu's service [45]
Patching the year's flaws	Software Update (study's pairing)	MS11-087, Apache 2.2.20 and 2.2.21, MS11-100 [44][27][53]

The library links T1498, T1499.004, T1553.002, T1550.002, T1021.002, T1588.004, T1598.003 and T1685 to no D3FEND countermeasure (Demonstrated [101]). ATT&CK mitigation pages exist for M1051 Update Software, M1050 Exploit Protection, M1017 User Training, M1032 Multi-factor Authentication, M1027 Password Policies, M1036 Account Use Policies, M1026 Privileged Account Management, M1037 Filter Network Traffic, M1031 Network Intrusion Prevention, M1049 Antivirus/Antimalware, M1021 Restrict Web-Based Content, M1054 Software Configuration, M1045 Code Signing, M1030 Network Segmentation and M1047 Audit (Demonstrated [102]). Advisory 2639658's T2EMBED.DLL workaround maps most closely to M1042 Disable or Remove Feature or Program and to M1050; the SecurID remediation to M1032; the Gmail advice to M1017 and M1047; and the CA untrust updates to M1054 (Inferred [42][10][22][29]).

Navigator layer

The study's Enterprise techniques are saved as one ATT&CK Navigator layer pinned to ATT&CK v20, navigator/library-layers/chronicle-2011.json, in the format of the existing chronicle layers: domain enterprise-attack, described as a curated case-study layer and not an official MITRE mapping (Demonstrated [104]). It lists the 66 techniques in the Enterprise table under each tactic they carry in v20.0, 82 technique-tactic entries in all, and is listed on the Navigator layers page. The ICS techniques are not in it. Scores show the basis, not severity, in the house scale set by the 2016 chronicle: 100 where an ATT&CK object prints the id, 70 where a primary source describes the behavior and this study assigns the id, 50 where only a Reported source supports it, and 40 for an Inferred mapping (Demonstrated [104]). The 54 techniques listed for C0002, S0038 or G0006 score 100, with a comment noting that APT1's techniques come from ATT&CK's group record and that Duqu's come from ATT&CK's software record; T1588.004, T1598.003, T1203, T1068, T1553.002, T1557, T1114.003, T1498, T1499.004 and T1491.002 score 70; T1657 scores 50; T1110 scores 40. Each entry's comment names the source numbers in the Sources table below.

Cross-cutting themes

Trust was the target. Certificates, information related to two-factor products and a code-signing certificate were each stolen or abused in 2011, so that what defenders trusted carried the attack (Confirmed [5][26][10][39]).

The vendors' fixes were removals. The answer to every CA failure was to take trust away: blocklists, untrusted roots and, for DigiNotar, the whole CA (Confirmed [8][6][29][28]).

Documents carried the exploits. An Excel attachment and a Word document delivered two of the year's zero-days, and NVD records an Office-document demonstration for a third (Confirmed [12][40][15]).

The record named places, not perpetrators. Comodo pointed to Iranian IP addresses, Google to victims in Iran and to Jinan, McAfee to China-based actors, and none named a state as a finding; the state attributions came later or from vendors (Confirmed [5][28][22][2]; Inferred).

Breaches became filings. RSA, Epsilon, Sony and DigiNotar's parent reported through 8-K and 6-K filings, and the SEC's October guidance followed (Confirmed [10][14][18][26][38]).

Courts did the takedowns. Two Microsoft civil cases, a government stop order and a criminal case that kept DNS working for victims all came in 2011 (Confirmed [9][34][16][47]).

Governments wrote strategy. The United States published international and defense strategies, a legislative proposal, an executive order and FedRAMP, and the UK published its strategy (Confirmed [20][65][77][91][94][92]).

What is overstated and what is understated

This section is the study's reading of the record (Inferred).

- **Overstated: Iranian state attribution for Comodo and DigiNotar.** Comodo's state-driven conclusion rests on indicators it calls circumstantial, DigiNotar's "politically inspired" line is the company's view, and Google's primary says only that affected users were primarily in Iran [5][32][28].
- **Overstated: "the RSA hack caused the Lockheed breach".** EMC's filing names no customer and speaks of an unsuccessful attack, Lockheed Martin names no attacker, and the link between them was not

checked [11][60].

- **Not re-sourced here: RSA's entry point.** Adobe and NVD name no victim; RSA's own account, which the FireEye Mandiant intrusion study carries, describes phishing e-mails with an Excel file carrying the Flash zero-day CVE-2011-0609, and this chronicle did not reopen it [12][13][103].
- **Overstated: the novelty of the APT label.** RSA used "Advanced Persistent Threat" as a category, not a named actor, and its filing does not say how the attackers entered [10].
- **Overstated: Duqu as an ICS weapon.** ICS-CERT found no ICS or vendor targeting, and ATT&CK's three ICS techniques for Duqu describe data theft, not control [41][45].
- **Overstated: BEAST.** It drew heavy attention but has no exploitation in the record and is not in KEV [37][54].
- **Overstated: the botnet figures.** Rustock's million computers and 30 billion spam a day and Kelihos's 3.8 billion are Microsoft's estimates, and Coreflood's release gives two million in its headline and hundreds of thousands in its text [9][34][16].
- **Overstated: the precision of ids on 2011 events.** No ATT&CK mapping existed in 2011, every technique id here is assigned in hindsight, and KEV came 11 to 14 years later [54].
- **Understated: the certificate authority collapse.** Three CA events in one year each produced a Microsoft trust-store advisory, and DigiNotar went from detection to bankruptcy in nine weeks [6][29][49][26][33].
- **Understated: the botnet law-enforcement firsts.** Kelihos was Microsoft's first botnet civil case naming a defendant [34]; Coreflood's court-authorized stop commands and Ghost Click's clean replacement DNS servers were new remedies in the record opened here (Inferred) [16][47].
- **Understated: routine standards work.** 4,172 CVE records were published, CWE 2.0 and CWSS shipped, NIST published continuous-monitoring and cloud guidance, and SSL 2.0 was prohibited and SSL 3.0 made Historic [95][89][79][80][83][86].
- **Understated: exploited flaws outside KEV.** The Apache Range-header and telnetd flaws were exploited in 2011 per NVD and are not in KEV [27][75][54].
- **Understated: the regulator record.** This study could not open the primaries for several 2011 regulator actions (listed under Scope and method), so it does not cover them.

Discrepancies in the record

- **Coreflood's size.** The release's headline says more than two million infected computers; its text describes a botnet of hundreds of thousands [16].
- **DNSChanger's count.** SDNY says more than four million computers; the FBI's account says about four million [46][47].
- **DigiNotar's untrust steps.** The trust list update of 29 August removed one root, KB2607712 on 6 September untrusted five, and KB2616676 on 13 September untrusted 11, rereleased on 19 September [29].
- **Sony's dates.** PSN and Qriocity were breached on 17 to 19 April; SOE's data on 16 and 17 April [17][18].
- **Duqu's first date.** Symantec gives early April 2011 for the first recorded attack and November 2010 for compile times [40].
- **Duqu and ICS.** ICS-CERT found no ICS targeting; ATT&CK lists three ICS techniques for S0038 [41][45].

- **The ICS-CERT Duqu alert's date.** The alert's number, 11-291 (the 291st day of 2011), dates it to 18 October (Inferred), and the revision opened describes the situation as of 21 October [41].
- **Night Dragon's attribution.** McAfee says the activity originated primarily in China; ATT&CK says researchers assessed a China-based group and names no group object [2][1].
- **The Night Dragon paper's copy.** McAfee's own URL returned an error; the text was read from a third-party mirror [2].
- **APT1's sponsor.** Mandiant says Unit 61398 is "similar to" APT1 and calls APT1 "likely government-sponsored"; ATT&CK attributes APT1 to Unit 61398 [56][57].
- **Monsegur's timeline.** His plea was entered on 15 August 2011 and unsealed on 6 March 2012; the home study dates his cooperation from about 7 June 2011 [4][103].

Sources

Every external source was opened on 12 or 13 November 2026, and the library data checks were run on the same days, as the Opened column shows. All are checked as of 13 November 2026. Grade is the source's evidence grade as used in this study. Addresses shown as code rather than as links refuse automated link checkers (SEC EDGAR and the SEC's guidance, the NVD API queries, Adobe's advisory and the ftc.gov release); copy them into a browser to open them.

#	Source	URL	Opened	Grade
1	MITRE ATT&CK, C0002 Night Dragon	https://attack.mitre.org/campaigns/C0002/	2026-11-12; 2026-11-13	Confirmed (the object and its techniques); Reported (the China-based assessment)
2	McAfee, Global Energy Cyberattacks: "Night Dragon", 10 Feb 2011 (third-party mirror; McAfee's own copy returned an error)	https://scadahacker.com/library/Documents/Cyber_Events/McAfee%20-%20Night%20Dragon%20-%20Global%20Energy%20Cyberattacks.pdf	2026-11-12	Confirmed (the vendor's findings)
3	NASDAQ OMX Group, Form 10-K for 2010, filed 24 Feb 2011 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1120193/000119312511045348/d10k.htm`	2026-11-13	Confirmed
4	FBI New York, Six hackers in the United States and abroad charged for crimes affecting over one million victims, 6 Mar 2012	https://archives.fbi.gov/archives/newyork/press-releases/2012/six-hackers-in-the-united-states-and-abroad-charged-for-crimes-affecting-over-one-million-victims	2026-11-13	Confirmed (that the charges and the plea were made); Reported (the alleged hacks)
5	Comodo, Comodo Fraud Incident report, 23 Mar 2011	https://www.comodo.com/Comodo-Fraud-Incident-2011-03-23.html	2026-11-12; 2026-11-13	Confirmed (the incident as Comodo states it); Reported (Comodo's attribution)
6	Microsoft Security Advisory 2524375, Fraudulent Digital Certificates Could Allow Spoofing, 23 Mar 2011	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2011/2524375	2026-11-12; 2026-11-13	Confirmed

#	Source	URL	Opened	Grade
7	US-CERT (CISA archive), Fraudulent SSL Certificates, 23 Mar 2011	https://www.cisa.gov/news-events/alerts/2011/03/23/fraudulent-ssl-certificates	2026-11-13	Confirmed
8	Mozilla Security Blog, Firefox Blocking Fraudulent Certificates, 22 Mar 2011	https://blog.mozilla.org/security/2011/03/22/firefox-blocking-fraudulent-certificates/	2026-11-12	Confirmed
9	Microsoft, Taking Down Botnets: Microsoft and the Rustock Botnet, 17 Mar 2011	https://blogs.microsoft.com/blog/2011/03/17/taking-down-botnets-microsoft-and-the-rustock-botnet/	2026-11-12; 2026-11-13	Confirmed (the takedown); the size figures are Microsoft's estimates
10	EMC Corporation, Form 8-K and Exhibit 99.1 (RSA open letter), filed 17 Mar 2011 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/790070/000119312511070159/d8k.htm` ; `https://www.sec.gov/Archives/edgar/data/790070/000119312511070159/dex991.htm`	2026-11-12; 2026-11-13	Confirmed
11	EMC Corporation, Form 10-Q, filed 5 Aug 2011 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/790070/000119312511212329/d10q.htm`	2026-11-12; 2026-11-13	Confirmed
12	Adobe, Security Advisory APSA11-01, 14 Mar 2011	`https://www.adobe.com/support/security/advisories/apsa11-01.html`	2026-11-12	Confirmed
13	NVD, CVE-2011-0609 (API record and detail page)	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2011-0609` ; https://nvd.nist.gov/vuln/detail/CVE-2011-0609	2026-11-12; 2026-11-13	Confirmed
14	Alliance Data Systems, Form 8-K exhibit on Epsilon, 6 Apr 2011 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1101215/000129993311001029/exhibit1.htm`	2026-11-13	Confirmed (the company's account)
15	NVD, CVE-2011-0611 (API record)	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2011-0611`	2026-11-12; 2026-11-13	Confirmed
16	FBI New Haven, Coreflood botnet action, 13 Apr 2011	https://archives.fbi.gov/archives/newhaven/press-releases/2011/nh041311.htm	2026-11-12; 2026-11-13	Confirmed
17	PlayStation Blog, Update on PlayStation Network and Qriocity, 26 Apr 2011	https://blog.playstation.com/2011/04/26/update-on-playstation-network-and-qriocity/	2026-11-12; 2026-11-13	Confirmed (the company's account)
18	Sony Corporation, Form 6-K, 3 May 2011 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/313838/000090342311000237/sony-6k_0503.htm`	2026-11-13	Confirmed
19	Sony Corporation, Form 6-K, 2 May 2011 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/313838/000090342311000234/sony-6k_0502.htm`	2026-11-13	Confirmed
20	The White House (archived), International Strategy for Cyberspace, May 2011	https://obamawhitehouse.archives.gov/sites/default/files/rss_viewer/international_strategy_for_cyberspace.pdf	2026-11-12; 2026-11-13	Confirmed
21	FBI Los Angeles, Member of hacking group LulzSec arrested for June 2011 intrusion of Sony Pictures computer systems, 22 Sep 2011	https://archives.fbi.gov/archives/losangeles/press-releases/2011/member-of-hacking-group-lulzsec-arrested-for-june-2011-intrusion-of-sony-pictures-computer-systems	2026-11-13	Confirmed (the arrest and that the indictment alleges SQL injection)

#	Source	URL	Opened	Grade
22	Google Official Blog, Ensuring your information is safe online, 1 Jun 2011	https://googleblog.blogspot.com/2011/06/ensuring-your-information-is-safe.html	2026-11-12; 2026-11-13	Confirmed
23	US-CERT (CISA archive), Gmail Phishing Attack, 2 Jun 2011	https://www.cisa.gov/news-events/alerts/2011/06/02/gmail-phishing-attack	2026-11-13	Confirmed
24	FBI, Sixteen individuals arrested in the United States for alleged roles in cyber attacks, 19 Jul 2011	https://archives.fbi.gov/archives/news/pressrel/press-releases/sixteen-individuals-arrested-in-the-united-states-for-alleged-roles-in-cyber-attacks	2026-11-12; 2026-11-13	Confirmed (as charged)
25	US-CERT (CISA archive), TA11-200A, Security Recommendations to Prevent Cyber Intrusions, 19 Jul 2011	https://www.cisa.gov/news-events/alerts/2011/07/19/security-recommendations-prevent-cyber-intrusions	2026-11-13	Confirmed
26	VASCO Data Security, Form 8-K Exhibit 99.1 on DigiNotar, 30 Aug 2011 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1044777/000119312511237215/dex991.htm`	2026-11-13	Confirmed
27	Apache HTTP Server, advisory for CVE-2011-3192, 24 Aug 2011 (final 31 Aug)	https://httpd.apache.org/security/CVE-2011-3192.txt	2026-11-12; 2026-11-13	Confirmed
28	Google Online Security Blog, An update on attempted man-in-the-middle attacks, 29 Aug 2011	https://security.googleblog.com/2011/08/update-on-attempted-man-in-middle.html	2026-11-12; 2026-11-13	Confirmed
29	Microsoft Security Advisory 2607712, Fraudulent Digital Certificates Could Allow Spoofing, 29 Aug 2011 (revised to 19 Sep)	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2011/2607712	2026-11-12; 2026-11-13	Confirmed
30	US-CERT (CISA archive), Fraudulent DigiNotar SSL Certificate, 30 Aug 2011	https://www.cisa.gov/news-events/alerts/2011/08/30/fraudulent-diginotar-ssl-certificate	2026-11-13	Confirmed
31	Mozilla Security Blog, Fraudulent *.google.com Certificate, 29 Aug 2011 (updated to 6 Sep)	https://blog.mozilla.org/security/2011/08/29/fraudulent-google-com-certificate/	2026-11-12	Confirmed
32	VASCO Data Security, Form 8-K Exhibit 99.3 (DigiNotar statement), 7 Sep 2011 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1044777/000119312511241796/dex993.htm`	2026-11-13	Confirmed (the filing); Reported (DigiNotar's view of the purpose)
33	VASCO Data Security, Form 8-K exhibit on DigiNotar's bankruptcy, Sep 2011 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1044777/000119312511251822/d234320dex991.htm`	2026-11-13	Confirmed
34	Microsoft, Microsoft Neutralizes Kelihos Botnet, Names Defendant in Case, 27 Sep 2011	https://blogs.microsoft.com/blog/2011/09/27/microsoft-neutralizes-kelihos-botnet-names-defendant-in-case/	2026-11-12; 2026-11-13	Confirmed (the case); the size figures are Microsoft's estimates

#	Source	URL	Opened	Grade
35	US-CERT (CISA archive), SSL/TLS Protocol Vulnerability, 27 Sep 2011	https://www.cisa.gov/news-events/alerts/2011/09/27/ssltls-protocol-vulnerability	2026-11-13	Confirmed
36	Microsoft Security Advisory 2588513, Vulnerability in SSL/TLS Could Allow Information Disclosure, 26 Sep 2011	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2011/2588513	2026-11-12	Confirmed
37	NVD, CVE-2011-3389 (API record)	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2011-3389`	2026-11-12	Confirmed
38	SEC Division of Corporation Finance, CF Disclosure Guidance: Topic No. 2, Cybersecurity, 13 Oct 2011	`https://www.sec.gov/divisions/corpfin/guidance/cfguidance-topic2.htm`	2026-11-12; 2026-11-13	Confirmed
39	CrySyS Lab, Duqu: A Stuxnet-like malware found in the wild, technical report v0.93, 14 Oct 2011	https://www.crysys.hu/publications/files/bencsathPBF11duqu.pdf	2026-11-12; 2026-11-13	Confirmed; Demonstrated (the researchers' analysis)
40	Symantec (Broadcom), W32.Duqu: The precursor to the next Stuxnet, v1.0 of 18 Oct 2011 to v1.4 of 23 Nov 2011	https://docs.broadcom.com/doc/w32-duqu-11-en	2026-11-13	Confirmed
41	ICS-CERT (CISA), ICS-ALERT-11-291-01E, W32.Duqu	https://www.cisa.gov/news-events/ics-alerts/ics-alert-11-291-01e	2026-11-12	Confirmed
42	Microsoft Security Advisory 2639658, Vulnerability in TrueType Font Parsing Could Allow Elevation of Privilege, 3 Nov 2011	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2011/2639658	2026-11-12; 2026-11-13	Confirmed
43	NVD, CVE-2011-3402 (API record and detail page)	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2011-3402` ; https://nvd.nist.gov/vuln/detail/CVE-2011-3402	2026-11-12	Confirmed
44	Microsoft Security Bulletin MS11-087, 13 Dec 2011	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2011/ms11-087	2026-11-12	Confirmed
45	MITRE ATT&CK, S0038 Duqu	https://attack.mitre.org/software/S0038/	2026-11-12	Confirmed
46	FBI New York (SDNY), Manhattan US Attorney charges seven individuals for engineering sophisticated internet fraud scheme, 9 Nov 2011	https://archives.fbi.gov/archives/newyork/press-releases/2011/manhattan-u.s.-attorney-charges-seven-individuals-for-engineering-sophisticated-internet-fraud-scheme-that-infected-millions-of-computers-worldwide-and-manipulated-internet-advertising-business	2026-11-12; 2026-11-13	Confirmed (as charged)
47	FBI, International cyber ring that infected millions of computers dismantled, 9 Nov 2011	https://www.fbi.gov/news/stories/international-cyber-ring-that-infected-millions-of-computers-dismantled	2026-11-12	Confirmed
48	Valve, Steam news message of 10 Nov 2011	https://store.steampowered.com/news/6761/	2026-11-13	Confirmed (the company's account)

#	Source	URL	Opened	Grade
49	Microsoft Security Advisory 2641690, Fraudulent Digital Certificates Could Allow Spoofing, 10 Nov 2011	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2011/2641690	2026-11-13	Confirmed
50	NVD, CVE-2011-2462 (API record)	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2011-2462`	2026-11-12; 2026-11-13	Confirmed
51	US-CERT (CISA archive), Multiple Programming Language Implementations Vulnerable to Hash Table Collision Attacks, 28 Dec 2011	https://www.cisa.gov/news-events/alerts/2011/12/28/multiple-programming-language-implementations-vulnerable-hash-table-collision-attacks	2026-11-13	Confirmed
52	CERT/CC, VU#903934, 28 Dec 2011	https://www.kb.cert.org/vuls/id/903934	2026-11-12	Confirmed
53	Microsoft Security Bulletin MS11-100, 29 Dec 2011	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2011/ms11-100	2026-11-12	Confirmed
54	CISA, Known Exploited Vulnerabilities catalog (JSON feed, version 2026.11.10)	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-12; 2026-11-13	Confirmed
55	Symantec (Broadcom), W32.Stuxnet Dossier v1.4, Feb 2011	https://docs.broadcom.com/doc/security-response-w32-stuxnet-dossier-11-en	2026-11-12	Confirmed
56	Mandiant, APT1: Exposing One of China's Cyber Espionage Units, Feb 2013	https://services.google.com/fh/files/misc/mandiant-apt1-report.pdf	2026-11-12	Confirmed (the vendor's findings and assessment); Reported (the hearing quotation)
57	MITRE ATT&CK, G0006 APT1	https://attack.mitre.org/groups/G0006/	2026-11-12	Confirmed
58	FBI, Most Wanted: Wang Dong (2014 W.D. Pa. indictment of five 3PLA officers)	https://www.fbi.gov/wanted/cyber/wang-dong	2026-11-12	Confirmed (as charged)
59	FBI, Most Wanted: Iranian DDoS attacks (2016 SDNY indictment)	https://www.fbi.gov/wanted/cyber/iranian-ddos-attacks	2026-11-12	Confirmed (as charged)
60	Lockheed Martin, Lockheed Martin Customer, Program and Employee Data Secure, 28 May 2011	https://news.lockheedmartin.com/2011-05-28-Lockheed-Martin-Customer-Program-and-Employee-Data-Secure	2026-11-12	Confirmed (the company's account)
61	MITRE ATT&CK, S0018 Sykipot	https://attack.mitre.org/software/S0018/	2026-11-12	Confirmed
62	MITRE ATT&CK, G0032 Lazarus Group	https://attack.mitre.org/groups/G0032/	2026-11-12	Confirmed
63	MITRE ATT&CK, G0004 Ke3chang	https://attack.mitre.org/groups/G0004/	2026-11-12	Confirmed
64	MITRE ATT&CK, S0143 Flame	https://attack.mitre.org/software/S0143/	2026-11-12	Confirmed
65	US Department of Defense, Strategy for Operating in Cyberspace, Jul 2011 (NIST ISPAB copy)	https://csrc.nist.gov/CSRC/media/Projects/ISPAB/documents/DOD-Strategy-for-Operating-in-Cyberspace.pdf	2026-11-12	Confirmed

#	Source	URL	Opened	Grade
66	MITRE ATT&CK, G0124 Windigo (with the G0041, G0081 and C0016 records in the library's data)	https://attack.mitre.org/groups/G0124	2026-11-12	Confirmed
67	Microsoft Malware Encyclopedia, Worm:Win32/Morto.A	https://www.microsoft.com/en-us/wdsi/threats/malware-encyclopedia-description?Name=Worm:Win32/Morto.A	2026-11-12	Confirmed
68	Microsoft Security Bulletin MS11-001, 11 Jan 2011 (with the year's numbering)	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2011/ms11-001	2026-11-12	Confirmed (dates); Inferred (the count)
69	NVD, CVE-2011-1823 (API record)	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2011-1823`	2026-11-12	Confirmed
70	Microsoft Security Bulletin MS11-040, 14 Jun 2011	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2011/ms11-040	2026-11-12	Confirmed
71	Microsoft Security Bulletin MS11-080, 11 Oct 2011	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2011/ms11-080	2026-11-12	Confirmed
72	NVD, CVE-2011-3544 (API record)	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2011-3544`	2026-11-12	Confirmed
73	Microsoft Security Bulletin MS11-083, 8 Nov 2011	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2011/ms11-083	2026-11-12	Confirmed
74	Microsoft Security Bulletin MS11-058, 9 Aug 2011	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2011/ms11-058	2026-11-12	Confirmed
75	NVD, CVE-2011-4862 (API record)	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2011-4862`	2026-11-12	Confirmed
76	ICS-CERT Monitor, January 2012	https://www.cisa.gov/sites/default/files/Monitors/ICS-CERT_Monitor_Jan2012.pdf	2026-11-12	Confirmed (ICS-CERT's incidents); Reported (the Threatpost item it quotes)
77	The White House (archived), Fact Sheet: Cybersecurity Legislative Proposal, 12 May 2011	https://obamawhitehouse.archives.gov/the-press-office/2011/05/12/fact-sheet-cybersecurity-legislative-proposal	2026-11-12	Confirmed
78	NIST, SP 800-39, Managing Information Security Risk, Mar 2011	https://csrc.nist.gov/pubs/sp/800/39/final	2026-11-12	Confirmed
79	NIST, SP 800-137, Information Security Continuous Monitoring, Sep 2011	https://csrc.nist.gov/pubs/sp/800/137/final	2026-11-12	Confirmed
80	NIST, SP 800-145, The NIST Definition of Cloud Computing, Sep 2011	https://csrc.nist.gov/pubs/sp/800/145/final	2026-11-12	Confirmed
81	NIST, SP 800-144, Guidelines on Security and Privacy in Public Cloud Computing, Dec 2011	https://csrc.nist.gov/pubs/sp/800/144/final	2026-11-12	Confirmed

#	Source	URL	Opened	Grade
82	NIST, SP 800-63-1, Electronic Authentication Guideline, Dec 2011	https://csrc.nist.gov/pubs/sp/800/63/1/final	2026-11-12	Confirmed
83	IETF, RFC 6176, Prohibiting Secure Sockets Layer (SSL) Version 2.0, Mar 2011	https://www.rfc-editor.org/rfc/rfc6176.txt	2026-11-12	Confirmed
84	IETF, RFC 6125, Representation and Verification of Domain-Based Application Service Identity, Mar 2011	https://www.rfc-editor.org/rfc/rfc6125.txt	2026-11-12	Confirmed
85	IETF, RFC 6265, HTTP State Management Mechanism, Apr 2011	https://www.rfc-editor.org/rfc/rfc6265.txt	2026-11-12	Confirmed
86	IETF, RFC 6101, The Secure Sockets Layer (SSL) Protocol Version 3.0, Aug 2011	https://www.rfc-editor.org/rfc/rfc6101.txt	2026-11-12	Confirmed
87	IETF, RFC 6376, DomainKeys Identified Mail (DKIM) Signatures, Sep 2011	https://www.rfc-editor.org/rfc/rfc6376.txt	2026-11-12	Confirmed
88	MITRE and SANS, 2011 CWE/SANS Top 25 Most Dangerous Software Errors, 27 Jun 2011	https://cwe.mitre.org/top25/archive/2011/2011_cwe_sans_top25.html	2026-11-12	Confirmed
89	MITRE, CWE news archive for 2011	https://cwe.mitre.org/news/archives/news2011.html	2026-11-12	Confirmed
90	ImperialViolet, Public key pinning, 4 May 2011	https://www.imperialviolet.org/2011/05/04/pinning.html	2026-11-12	Confirmed (the implementer's statement)
91	Federal Register, Executive Order 13587, 13 Oct 2011 (signed 7 Oct)	https://www.federalregister.gov/documents/2011/10/13/2011-26729/structural-reforms-to-improve-the-security-of-classified-networks-and-the-responsible-sharing-and	2026-11-12	Confirmed
92	UK Cabinet Office, The UK Cyber Security Strategy, 25 Nov 2011	https://www.gov.uk/government/publications/cyber-security-strategy	2026-11-12	Confirmed
93	FTC, Facebook settles FTC charges that it deceived consumers by failing to keep privacy promises, 29 Nov 2011	`https://www.ftc.gov/news-events/news/press-releases/2011/11/facebook-settles-ftc-charges-it-deceived-consumers-failing-keep-privacy-promises`	2026-11-12	Confirmed
94	OMB, Federal CIO memorandum, Security Authorization of Information Systems in Cloud Computing Environments (FedRAMP), 8 Dec 2011	https://obamawhitehouse.archives.gov/sites/default/files/omb/assets/egov_docs/fedrampmemo.pdf	2026-11-12	Confirmed

#	Source	URL	Opened	Grade
95	NVD, CVE API query by publication date, 2011 (four windows; first window shown)	`https://services.nvd.nist.gov/rest/json/cves/2.0?pubStartDate=2011-01-01T00:00:00.000&pubEndDate=2011-04-30T23:59:59.999`	2026-11-12	Confirmed (query result)
96	MITRE ATT&CK, T1588.004 Digital Certificates	https://attack.mitre.org/techniques/T1588/004/	2026-11-12	Confirmed (the technique); Inferred (its binding to 2011 events)
97	MITRE CAPEC, CAPEC-459 Creating a Rogue Certification Authority Certificate	https://capec.mitre.org/data/definitions/459.html	2026-11-12	Confirmed (the pattern); Inferred (its binding)
98	MITRE CWE, CWE-326 Inadequate Encryption Strength	https://cwe.mitre.org/data/definitions/326.html	2026-11-12	Confirmed
99	MITRE D3FEND, Certificate Pinning	https://d3fend.mitre.org/technique/d3f:CertificatePinning/	2026-11-12	Confirmed
100	TeamStarWolf library, ATT&CK data files (`data/attack/`, `data/attack/ics/`, including `campaigns.jsonl`)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-12; 2026-11-13	Confirmed; Demonstrated
101	TeamStarWolf library, weakness and countermeasure data (`data/weaknesses/cwe.jsonl`, `capec.jsonl`, `data/attack/technique_to_d3fend.jsonl`)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data/weaknesses	2026-11-12; 2026-11-13	Demonstrated
102	TeamStarWolf library, `mitre/` page tree (technique, group, software, campaign, CAPEC, D3FEND and mitigation pages)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/mitre	2026-11-12; 2026-11-13	Demonstrated
103	TeamStarWolf library, case studies on main (home studies named in the text)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/case-studies	2026-11-12; 2026-11-13	Confirmed (for the fact that a study is the home and for the facts it carries from its own sources)
104	TeamStarWolf library, chronicle Navigator layers (`navigator/library-layers/chronicle-2016.json` and the later years)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/navigator/library-layers	2026-11-13	Demonstrated

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Notable Incidents, Threat Actors, Malware Families, CVE Reference
- Certificate Trust Incident Response, Cryptography, Browser Security, Email Security, Identity and Access Management, CWE Reference, CAPEC Reference, D3FEND Reference, GRC and Compliance, Vulnerability Management, Incident Response, ICS/OT Security
- Home studies: Stuxnet; China-attributed threat actors; Iran-attributed threat actors; North Korea-attributed threat actors; United States-attributed threat actors; Four Books on Cybercrime; The Hacker and the State; E-Commerce Threats; FireEye Mandiant intrusion 2020; eMudhra CA compromise; APT41; ICS attacks and advisories; Log4Shell; SolarWinds SUNBURST; npm supply-chain attacks; Hugging Face supply chain
- Series: 1993, 1994, 1995, 1996, 1997, 1998, 1999, 2000, 2001, 2002, 2003, 2004, 2005, 2006, 2007, 2010, 2016, 2017, 2018, 2019, 2020, 2021, 2022, 2023, 2024, 2025, 2026
- Techniques: T1588.004 Digital Certificates, T1557 Adversary-in-the-Middle, T1566.001 Spearphishing Attachment, T1566.002 Spearphishing Link, T1598.003 Spearphishing Link, T1203 Exploitation for Client Execution, T1068 Exploitation for Privilege Escalation, T1553.002 Code Signing, T1078 Valid Accounts, T1114.003 Email Forwarding Rule, T1021.001 Remote Desktop Protocol, T1110 Brute Force, T1190 Exploit Public-Facing Application, T1056.001 Keylogging, T1685 Disable or Modify Tools, T1498 Network Denial of Service, T1499.004 Application or System Exploitation, T1491.002 External Defacement, T1657 Financial Theft; the full list is in the Part 13 table
- CAPEC: CAPEC-1, CAPEC-55, CAPEC-63, CAPEC-66, CAPEC-68, CAPEC-88, CAPEC-92, CAPEC-94, CAPEC-100, CAPEC-112, CAPEC-163, CAPEC-206, CAPEC-459, CAPEC-473, CAPEC-475, CAPEC-555, CAPEC-560, CAPEC-561, CAPEC-568, CAPEC-571, CAPEC-578, CAPEC-644
- Groups, software and campaigns: Night Dragon C0002; Duqu S0038; APT1 G0006; ASPXSpy S0073; PsExec S0029; at S0110; gsecdump S0008; zwShell S0350; Stuxnet S0603; Sykipot S0018; Lazarus Group G0032; Ke3chang G0004; Flame S0143; Strider G0041; Tropic Trooper G0081; Windigo G0124; Ebury S0377; Operation Dust Storm C0016
- Navigator layers, including this study's layer, chronicle-2011.json